

Ingénieur SOC

Protéger les services. Investiguer les alertes.
Construire une surveillance fiable.

AUTEURS

Touhami KASBAOUI · SOC Manager
Toufik AIRANE · Cybersecurity Manager
Mouad ILMI · SOC Architect

Comprendre le risque · Analyser les preuves · Agir dans un cadre autorisé

Les auteurs de la formation

01

Touhami KASBAOUI

SOC Manager

02

Toufik AIRANE

Cybersecurity Manager

03

Mouad ILMI

SOC Architect

Public visé et participants attendus

01

Pour qui ?

Étudiants, débutants, personnes en reconversion et futurs analystes SOC. Le vocabulaire est expliqué avant d'être utilisé dans les exercices.

02

Avec quels prérequis ?

Savoir utiliser un navigateur, ouvrir un fichier et décrire une situation. Aucune expérience préalable de Wazuh ou d'administration cloud n'est supposée pour les bases.

03

Comment participer ?

Reformuler, poser des questions et justifier une réponse à partir des faits fournis. Distinguer ce que l'on sait, ce que l'on suppose et ce qui manque.

Périmètre et limites de la formation

01

Ce que nous étudions

Fondements cyber, raisonnement d'investigation SOC et principes d'architecture Wazuh. Les exemples professionnels sont fictifs et indépendants; aucune organisation réelle n'est mise en cause.

02

Ce que nous ne promettons pas

Trois jours ne constituent ni une certification professionnelle ni une autonomie d'expert. Les approfondissements prolongent le cours; tous les ateliers ne sont pas exécutés en séance.

03

Les limites de pratique

Pas d'attaque réelle, de malware exécuté ou d'intervention en production. Une manipulation technique exige un environnement isolé, autorisé et préparé par le formateur.

Objectifs et acquis attendus

01

Comprendre et protéger

Expliquer la valeur de l'information, CIAT et vie privée. Distinguer faiblesse, vulnérabilité et risque; proposer une protection et expliquer ses limites.

02

Raisonner et investiguer

Séparer fait, hypothèse et conclusion. Relier des traces, rechercher une explication concurrente et transmettre une escalade utile sans dépasser son mandat.

03

Relier technique et décision

Décrire le trajet d'un événement vers une alerte Wazuh. Identifier les preuves nécessaires pour vérifier collecte, détection, accès et reprise d'un service.

Contributions et ressources de référence

01

Supports conservés

Les 72 diapositives SOC Analyst et les 55 diapositives SOC Architecture conservent leurs contenus et notes. Leur provenance est indiquée dans la correspondance des sources.

02

Références techniques

Les apports citent notamment NIST, ANSSI, CNIL, MITRE, FIRST, CISA et la documentation Wazuh. Les références détaillées figurent dans les notes des diapositives.

03

Attribution, pas parrainage

Remercier les auteurs et organismes pour les ressources citées ne signifie pas qu'ils financent, certifient ou approuvent cette formation. Aucun soutien non documenté n'est revendiqué.

Comment transmettre un retour utile

01

Situer le point

Indiquer le numéro et le titre de la diapositive. Préciser si le problème concerne une définition, un exemple, une source, une consigne ou la lisibilité.

02

Décrire et étayer

Expliquer ce qui paraît ambigu ou incorrect, proposer une reformulation et joindre une référence si disponible. Ne transmettre ni secret ni donnée personnelle réelle.

03

Échanger et vérifier

En séance, adresser le retour au formateur pendant les questions ou le débrief. Discuter la correction et vérifier la version révisée; un désaccord argumenté est bienvenu.

Vue d'ensemble : des fondements à la pratique SOC

01

Jour 1 · Comprendre

Pourquoi la cybersécurité compte; sécurité et vie privée; vulnérabilités et faiblesses; gestion du risque; acteurs et réglementation; comportement rationnel.

02

Jour 2 · Investiguer

Étudier SSH, phishing et ransomware en séance. Les 72 diapositives Analyst sont conservées ; les autres scénarios servent à l'approfondissement.

03

Jour 3 · Concevoir

Suivre architecture, collecte, règles, FIM, droits et reprise. Les 55 diapositives Architecture restent disponibles, avec Wazuh intégré par sujet.

Fondements de la cybersécurité

Un cours pour débiter : partir d'un service réel,
comprendre les menaces et justifier une protection.

Définitions expliquées · Exemples concrets · Exercices guidés et corrigés séparés

1 · Pourquoi la cybersécurité est importante

La cybersécurité protège des activités concrètes. Commandes, dossiers du personnel, messagerie et factures illustreront, dans des situations professionnelles indépendantes, ce que la sécurité protège.

À L'ISSUE DE CE CHAPITRE, VOUS SAUREZ...

- 1 Relier une information à un service et à ses utilisateurs.
- 2 Expliquer les conséquences humaines et métier d'un incident.
- 3 Relier personnes, organisation du travail et dépendances techniques.

La cybersécurité protège une activité

La cybersécurité protège les informations et les systèmes numériques pour que les personnes puissent travailler et utiliser les services de façon fiable.

Elle associe des personnes, des règles et des moyens techniques. Elle réduit les risques liés aux attaques, mais aussi aux erreurs et aux pannes. Protéger seulement les ordinateurs ne suffit pas : une procédure de paiement mal conçue peut permettre une fraude sans piratage. Le but est de limiter les dommages et de savoir réagir, pas de promettre le risque zéro.

Une commande bloquée

Un serveur fonctionne mais le service commercial ne peut plus valider les commandes. Le besoin à protéger est leur traitement, pas seulement le voyant vert du serveur.

À RETENIR

Commencer par « qui a besoin de faire quoi ? », avant de choisir un outil.

Une donnée devient utile dans un contexte

Une donnée est une valeur enregistrée. L'information est le sens que l'on en tire pour comprendre ou décider.

« 120 » seul renseigne peu. « La facture validée de juin comporte un montant de 120 € TTC » permet une décision de paiement. Le contexte, la date et l'origine comptent autant que la valeur. Cette information existe sur plusieurs supports : application, fichier exporté, courriel ou feuille imprimée. La protection doit suivre ses copies, pas seulement l'application d'origine.

Les montants à payer

Une ancienne liste de factures, envoyée au comptable sans sa date, peut provoquer une mauvaise décision même si personne ne l'a falsifiée.

À RETENIR

Identifier la donnée, son contexte, ses copies et la personne responsable de son usage.

Du besoin au service : suivre les dépendances

Pour traiter une commande, plusieurs éléments doivent fonctionner ensemble. Une dépendance oubliée peut arrêter tout le service.

- | | | |
|-----------|------------------------|--|
| 01 | Besoin | Le service commercial doit confirmer une commande avant la date de livraison. |
| ↓ | | |
| 02 | Information | Référence client, produits choisis et conditions de vente permettent la décision. |
| ↓ | | |
| 03 | Application | Le portail enregistre la commande et son état de validation. |
| ↓ | | |
| 04 | Supports | Poste, réseau, serveur et stockage rendent le portail accessible. |
| ↓ | | |
| 05 | Responsabilités | Le service commercial valide la commande; l'équipe technique maintient les supports. |

À RETENIR Une machine est un support; la priorité vient du service et des personnes qui en dépendent.

Métier, technologie et personnes : des dépendances réciproques

Une activité repose sur des outils, des décisions et des personnes. Une protection qui ignore l'un de ces éléments peut échouer malgré un outil performant.

Le métier définit le résultat et l'échéance; la technologie permet de traiter les informations; les personnes interprètent, valident et signalent. Une procédure impraticable encourage les contournements. Un outil indisponible empêche parfois une vérification pourtant obligatoire. Améliorer la sécurité demande donc de regarder le travail réel, les responsabilités et les solutions de secours, sans réduire l'erreur à une faute individuelle.

La livraison urgente

Le service logistique doit confirmer une adresse, mais le portail est indisponible. Une procédure de secours autorisée évite d'envoyer le fichier clients depuis une messagerie personnelle.

À RETENIR

Demander ensemble : quel besoin, quel outil, quelle personne et quelle solution si cela ne fonctionne plus ?

2 · Les principes de sécurité de l'information et de vie privée

Protéger l'information demande de définir les besoins CIAT et de respecter les personnes. Les accès, le poste et le réseau permettent de comprendre où ces protections agissent et où elles s'arrêtent.

À L'ISSUE DE CE CHAPITRE, VOUS SAUREZ...

- 1 Distinguer confidentialité, intégrité, disponibilité, traçabilité et vie privée.
- 2 Relier identité, authentification, autorisation et session aux droits nécessaires.
- 3 Expliquer les protections et les limites d'un poste, d'un échange web et de la défense en profondeur.

CIAT : quatre questions avant de protéger

CIAT désigne ici Confidentialité, Intégrité, Availability (disponibilité) et Traçabilité. Ce repère aide à décrire le besoin de protection.

Qui peut lire ? Les données sont-elles exactes et protégées des changements non autorisés ? Sont-elles accessibles quand il le faut ? Peut-on reconstituer les opérations ? Les quatre questions se complètent. Le « A » vient du mot anglais availability. Le « T » est un ajout pédagogique aux trois objectifs classiques; ce n'est pas un acronyme universel.

Une facture à payer

Le montant doit rester exact, la facture accessible à l'échéance, ses lecteurs autorisés et son approbation reconstituable.

À RETENIR

Une même information peut subir plusieurs types d'atteinte en même temps.

Confidentialité ou intégrité : lire n'est pas modifier

Une information peut rester exacte tout en étant divulguée, ou rester secrète tout en étant falsifiée.

Confidentialité : les bons lecteurs

Les personnes et services non autorisés ne doivent pas accéder à l'information. Une liste de salaires envoyée à tout le personnel rompt cette protection, même si tous les montants sont corrects.

Intégrité : un contenu fiable

Les modifications et destructions non autorisées doivent être empêchées ou détectées. Remplacer le compte bancaire d'un fournisseur dans une facture menace l'intégrité, même si seul le comptable peut la lire.

Deux protections distinctes

Restreindre les destinataires protège la lecture; faire valider le compte bancaire protège la décision de paiement.

À RETENIR

Un fichier secret n'est pas forcément correct; un fichier correct n'est pas forcément bien protégé.

Disponibilité et traçabilité : utiliser puis expliquer

Un service utile doit fonctionner au bon moment et permettre de comprendre les opérations sensibles.

Disponibilité : au moment requis

Les utilisateurs autorisés peuvent accéder aux données et au service selon leur besoin. Une panne le jour du paiement des salaires peut empêcher les virements; la même panne pendant une maintenance prévue n'a pas le même impact.

Traçabilité : une histoire vérifiable

Des traces indiquent quel compte a fait quelle action, sur quoi, quand et avec quel résultat. Elles doivent être conservées et protégées. Un nom de compte seul ne prouve pas qui était devant le clavier.

Le paiement contesté

La facture a été payée, mais l'approbation a disparu. La disponibilité a été assurée; la traçabilité reste insuffisante.

À RETENIR

Pour expliquer une opération, il faut des traces fiables, pas seulement des données encore accessibles.

Vie privée et confidentialité ne sont pas synonymes

Protéger un secret ne rend pas automatiquement légitimes sa collecte et son utilisation.

Confidentialité

Elle limite l'accès aux personnes autorisées. Les dossiers du personnel ne doivent pas être ouverts à tous les salariés. Des droits et un stockage protégé réduisent les divulgations.

Vie privée et données personnelles

Une donnée personnelle se rapporte à une personne identifiable, directement ou indirectement. Il faut aussi examiner pourquoi on la collecte, combien de temps on la garde, à qui on la transmet et ses effets sur les personnes.

Un suivi excessif

Suivre en permanence la position des salariés pour compter les présences peut être excessif, même sans aucune fuite.

À RETENIR

« Nous gardons cela secret » ne répond pas à « avons-nous besoin de collecter cela ? ».

Collecter moins et garder pour une raison

La minimisation consiste à ne collecter que les données nécessaires à un objectif défini. La conservation doit elle aussi être justifiée.

Pour chaque formulaire, expliquer l'usage des champs, les destinataires et la durée prévue. Une adresse de contact peut être utile au traitement d'une commande; un dossier médical complet ne l'est pas automatiquement. Prévoir un interlocuteur pour les demandes des personnes. Accès, rectification ou effacement dépendent des règles applicables et peuvent comporter des exceptions.

La réservation d'un repas professionnel

Pour prévoir les repas d'une réunion, le service organisateur cherche le besoin utile, pas toute l'histoire médicale du participant. Les informations sensibles nécessitent un examen spécifique.

À RETENIR

Réduire les données inutiles réduit aussi ce qui pourrait être perdu, exposé ou détourné.

Exercice 1 · Les factures sont-elles protégées ?

SITUATION À ANALYSER

Un fichier de factures aux montants exacts est envoyé par erreur à tous les clients, qui ne sont autorisés à consulter que leurs propres factures. Le portail officiel reste accessible. Le même jour, un montant est changé sans validation; l'historique indique seulement « compte partagé ». Aucun autre élément n'est disponible.

- 01** Quelles propriétés CIAT sont atteintes ou incertaines ? Justifiez avec les faits.
- 02** Pourquoi le portail accessible ne suffit-il pas à dire que tout va bien ?
- 03** Proposez une mesure pour la diffusion et une pour les modifications.

Correction 1 · Trois problèmes, pas une panne

Le service disponible n'efface ni la fuite d'informations ni la modification non autorisée.

- | | | |
|-----------|--|---|
| 01 | Identifier les atteintes | L'envoi aux clients non autorisés touche la confidentialité. Le montant modifié sans validation touche l'intégrité. Le compte partagé affaiblit la traçabilité; il ne permet pas d'attribuer l'acte à une personne. |
| 02 | Ne pas inventer une indisponibilité | Le portail reste accessible dans l'énoncé : aucune panne n'est établie. La confiance dans les factures est pourtant altérée. Sécurité et disponibilité ne sont pas synonymes. |
| 03 | Adapter les protections | Restreindre les destinataires et contrôler l'envoi; utiliser des comptes nominatifs, limiter les modifications et conserver la validation. Signaler aussi la divulgation selon la procédure interne. |

À RETENIR Une bonne réponse relie chaque mesure au problème qu'elle doit réduire.

Le poste de travail et le système d'exploitation

Le poste est l'équipement utilisé par la personne. Son système d'exploitation organise les ressources et permet aux applications de fonctionner.

Le processeur exécute les instructions, la mémoire sert au travail en cours et le stockage conserve les fichiers. Le système, comme Windows ou Linux, gère ces ressources et les permissions. Le navigateur est une application : il affiche le portail, mais les dossiers peuvent être conservés sur un serveur distant. Fermer le navigateur ne supprime pas ces dossiers.

Le portail des commandes

Le poste du service commercial affiche un dossier reçu depuis le serveur. Une panne du poste, du réseau ou du serveur peut produire le même symptôme : « je ne vois plus le dossier ».

À RETENIR

Distinguer l'endroit où l'on consulte un service de l'endroit où ses données sont conservées.

Fichier, programme, processus : stocker ou agir

Un programme enregistré et ce programme en train de fonctionner sont deux choses différentes.

Fichier : ce qui est conservé

Un fichier contient des données ou des instructions. Un programme est un ensemble d'instructions, souvent stocké dans des fichiers. Le nom et l'extension aident à se repérer, mais ne garantissent ni le contenu ni son innocuité.

Processus : ce qui s'exécute

Un processus est une instance d'un programme en cours d'exécution. Il utilise de la mémoire et les droits d'un compte. Un navigateur peut créer plusieurs processus; le nombre ou le nom ne suffisent pas à détecter une attaque.

Une pièce jointe

Recevoir un fichier n'est pas la même chose que l'exécuter. Il faut préciser ce qui a été ouvert et avec quelle application.

À RETENIR

Pour comprendre une action, chercher quel processus agit, sous quel compte et sur quelle ressource.

Identité, authentification, autorisation : trois contrôles

L'identité annoncée, sa preuve et les droits accordés répondent à des questions différentes.

01 S'identifier

« Je suis le compte utilisateur-01. » L'identifiant indique qui demande l'accès; il n'est pas un secret.



02 S'authentifier

Le service vérifie une preuve liée au compte, par exemple un secret ou un moyen enregistré.



03 Être autorisé

Le service décide si ce compte peut effectuer cette action sur cette ressource.

À RETENIR

Réussir sa connexion ne donne pas le droit de consulter tous les dossiers.

MFA : plusieurs facteurs, pas deux mots de passe

MFA signifie Multi-Factor Authentication, ou authentification multifacteur. Elle combine des facteurs distincts : savoir, posséder ou être.

Un mot de passe relève de ce que l'on sait; un appareil ou une clé enregistrée peut apporter la possession; une vérification biométrique relève de ce que l'on est. Deux mots de passe restent un seul type de facteur. Les méthodes ne résistent pas toutes autant au phishing : privilégier les moyens résistants quand ils sont disponibles, et refuser toute validation non initiée.

Une demande inattendue

Une salariée reçoit une demande d'approbation alors qu'elle ne se connecte pas. Elle refuse et signale; elle ne valide pas pour faire disparaître la notification.

À RETENIR

La MFA réduit le risque de vol de compte; elle ne protège pas contre tous les scénarios.

La session : rester connecté, rester vigilant

Après l'authentification, une session permet de continuer à utiliser le service sans représenter sa preuve à chaque clic.

Un cookie ou un jeton peut représenter cette session. Ce petit élément numérique est sensible : sa copie peut parfois permettre d'agir comme l'utilisateur. Il ne faut pas le placer dans un ticket ou une capture partagée. La durée, la fermeture et la révocation des sessions comptent. Changer le mot de passe ne ferme pas forcément toutes les sessions déjà ouvertes.

Le poste partagé Une personne quitte son bureau en laissant son portail ouvert. La suivante pourrait consulter les dossiers sans connaître son mot de passe.

À RETENIR Verrouiller son poste et suivre la procédure de fin ou de révocation des sessions.

Exercice 2 · Connectée, mais pas autorisée

SITUATION À ANALYSER

Une salariée se connecte avec son mot de passe et une clé de sécurité enregistrée. Elle voit son dossier du personnel, mais le portail refuse celui d'un autre salarié. Un collègue propose de lui prêter un compte de gestion des ressources humaines (RH). Elle laisse ensuite sa session ouverte sur un poste partagé.

- 01** Le refus indique-t-il un échec d'authentification ? Expliquez.
- 02** Pourquoi le compte de gestion RH n'est-il pas une solution acceptable ?
- 03** Quel risque subsiste malgré la MFA et quelle action simple le réduit ?

Correction 2 · Une limite d'accès peut être normale

La salariée a prouvé son accès au compte; elle n'a pas pour autant reçu les droits de gestion RH.

01 Authentification réussie

Elle consulte son dossier du personnel après connexion : le service l'a authentifiée. Le refus du dossier d'autrui correspond ici à une décision d'autorisation, pas à un mot de passe incorrect.

02 Pas de prêt de compte

Le compte de gestion RH a une autre mission et expose d'autres données. Le partager contourne la limitation des droits et rend les actions moins attribuables.

03 Protéger la session

La MFA a servi à ouvrir l'accès; elle ne protège pas une session laissée utilisable. Verrouiller le poste et fermer la session selon la procédure réduit ce risque.

À RETENIR

Un contrôle fonctionne aussi lorsqu'il refuse correctement une action hors mission.

Réseau et IP : acheminer, pas identifier une personne

Un réseau permet à des équipements d'échanger. IP signifie Internet Protocol : des adresses servent à acheminer les échanges entre réseaux.

Un poste envoie ses données par petits ensembles appelés paquets. Sur le réseau local, des équipements relient les postes; un routeur permet de joindre d'autres réseaux. L'adresse IP situe un point de communication, pas un humain : elle peut changer ou être partagée. Pour enquêter, il faut rapprocher adresse, heure, équipement et compte.

Une adresse réattribuée

L'adresse fictive 192.0.2.10 appartient au poste A le matin, puis au poste B après réattribution. Une observation sans heure ne permet pas de choisir entre eux.

À RETENIR

Une adresse IP est un indice à contextualiser, jamais une identité humaine suffisante.

DNS : retrouver une destination à partir d'un nom

DNS signifie Domain Name System, système de noms de domaine. Il permet notamment de retrouver des adresses à partir d'un nom.

Un résolveur recherche l'information demandée et peut garder temporairement une réponse en cache. Le navigateur peut ainsi retrouver où joindre le portail. Le DNS ressemble à un annuaire, mais il peut donner plusieurs réponses ou d'autres informations qu'une adresse. Résoudre un nom ne prouve ni la connexion au site, ni un téléchargement, ni sa fiabilité.

Un nom dans les traces

Le poste cherche portail.invalid. Le suffixe .invalid est réservé à l'exemple; cette recherche fictive ne prouve pas que le portail a été ouvert.

À RETENIR

Le nom recherché, l'adresse obtenue et l'action réalisée sont trois informations différentes.

HTTP : le client demande, le serveur répond

HTTP signifie Hypertext Transfer Protocol. Ce protocole décrit des requêtes et des réponses entre un client, comme le navigateur, et un serveur web.

Une requête précise une action et une ressource. GET demande une représentation; POST soumet des données selon l'application. La réponse contient un code et éventuellement un contenu. Un code 200 signale un succès au niveau HTTP, pas la légitimité de l'utilisateur. Un code 404 indique une ressource non trouvée, pas automatiquement une attaque.

Afficher une facture

Le navigateur demande une page; le serveur vérifie les droits et construit la réponse. Un journal HTTP peut montrer le chemin et le code, sans montrer toutes les décisions internes.

À RETENIR

Interpréter le code avec la requête, l'identité et le contexte de l'application.

TLS et HTTPS : protéger le trajet, pas tout le service

TLS signifie Transport Layer Security. Il protège la confidentialité et l'intégrité des échanges. HTTPS est l'usage de HTTP protégé par TLS.

Le navigateur vérifie notamment que le serveur présente une preuve acceptable pour le nom demandé. Un certificat est un document numérique utilisé dans cette vérification. Un canal protégé limite la lecture ou la modification pendant le trajet, mais ne rend pas le site honnête et ne protège pas un poste déjà compromis. Un avertissement de validation ne doit pas être ignoré.

La fausse page sécurisée

Un site trompeur peut avoir une connexion HTTPS valide pour son propre nom. Le secret saisi volontairement sur ce site lui est tout de même remis.

À RETENIR

Vérifier la destination attendue; ne pas confondre connexion protégée et demande légitime.

Consulter une facture : le trajet simplifié d'une requête

Ce schéma montre les grandes dépendances d'une visite web, pas chaque paquet ni toutes les variantes de protocole.

- | | | |
|-----------|------------------------------|--|
| 01 | Choisir le nom | Un utilisateur ouvre l'adresse officielle connue du portail, pas un lien reçu au hasard. |
| ↓ | | |
| 02 | Résoudre et joindre | Le DNS aide à obtenir une adresse; le réseau permet de joindre le serveur. |
| ↓ | | |
| 03 | Protéger le canal | TLS vérifie le serveur attendu et protège les échanges HTTPS. |
| ↓ | | |
| 04 | Demander et contrôler | HTTP porte la demande; l'application contrôle la session et les droits sur la facture. |
| ↓ | | |
| 05 | Renvoyer le résultat | Le serveur répond; le navigateur affiche la facture autorisée ou un refus. |

À RETENIR Une panne à une étape ne prouve pas une attaque; un succès de transport ne prouve pas l'autorisation.

Exercice 3 · Ce que les traces ne disent pas

SITUATION À ANALYSER

Trois faits fictifs : le poste du service commercial a recherché un nom inhabituel dans le DNS; une connexion HTTPS valide a ensuite été établie vers ce nom; une page a répondu avec le code HTTP 200. On ne dispose ni du contenu envoyé ni du journal de l'application.

- 01** Que peut-on affirmer à partir de ces trois faits ?
- 02** Pourquoi HTTPS et 200 ne prouvent-ils pas que le site était légitime ?
- 03** Quelle information manque pour conclure à un vol de dossiers ?

Correction 3 · Un échange n'est pas encore un vol

Les faits décrivent une recherche de nom puis un échange web; le contenu et le sens métier restent inconnus.

- | | | |
|-----------|--------------------------------------|--|
| 01 | Affirmer ce qui est observé | Selon les sources disponibles, le poste a recherché le nom, établi un canal protégé et reçu un statut 200. Cela ne désigne pas l'humain qui a agi. |
| 02 | Respecter la portée technique | HTTPS protège le trajet vers le nom vérifié, pas la bienveillance du site. Le code 200 décrit une réponse HTTP; il ne certifie ni l'autorisation ni l'absence de tromperie. |
| 03 | Chercher une preuve adaptée | Pour un vol supposé, rechercher une action de lecture ou d'envoi de dossiers et son périmètre, avec des sources autorisées. Demander le contexte utilisateur sans diffuser de données sensibles. |

À RETENIR

Une bonne analyse sait dire « ce n'est pas encore établi » et préciser comment le vérifier.

Approfondissement réseau : ports et transports

Un port est un repère numérique pour un service sur un équipement. Le transport organise l'échange entre les deux extrémités.

TCP, Transmission Control Protocol, fournit un flux ordonné avec retransmission. UDP, User Datagram Protocol, transporte des messages sans ces garanties propres; une application peut en ajouter. Une conversation se décrit avec protocole, adresses et ports source et destination. Le port habituel aide à chercher, mais ne prouve pas l'application réelle.

Le numéro 443

Le port 443 est habituel pour HTTPS, mais voir ce numéro ne suffit pas à certifier le contenu. Certaines versions du Web utilisent des transports différents.

À RETENIR

Pour diagnostiquer, distinguer accès réseau, connexion de transport et résultat applicatif.

Chiffrement et empreinte : protéger ou comparer

Ces mécanismes répondent à des besoins différents et ne remplacent pas la gestion des accès.

Chiffrement : rendre illisible

Une clé permet de protéger des données et de les relire avec le mécanisme adapté. La clé doit elle-même être protégée et récupérable selon la politique prévue. Une sauvegarde chiffrée sans clé utilisable peut devenir impossible à restaurer.

Empreinte : détecter une différence

Le hachage produit une empreinte à partir d'un contenu. Comparer deux empreintes aide à repérer une modification. Ce n'est pas du chiffrement réversible; une empreinte seule ne dit ni qui a modifié le fichier ni pourquoi.

La facture mise à jour

Une empreinte différente signale un changement, pas sa légitimité. Il faut comparer à une référence fiable et à la validation métier.

À RETENIR

Chiffrer protège un secret; comparer une empreinte aide à contrôler un contenu.

Cloud : déléguer des tâches, pas toute responsabilité

Le cloud fournit des ressources ou des applications à distance. Le partage des tâches de sécurité dépend du service choisi et du contrat.

IaaS (Infrastructure as a Service) fournit des ressources d'infrastructure; PaaS (Platform as a Service), une plateforme; SaaS (Software as a Service), une application. Le fournisseur prend en charge des couches différentes, mais le client garde des décisions sur ses données, ses utilisateurs et ses paramètres. Journaux, sauvegardes et accès de secours doivent être vérifiés, pas supposés inclus.

La messagerie hébergée

Le fournisseur entretient son application; le client doit encore retirer le compte d'un salarié parti et limiter les partages de dossiers.

À RETENIR

Demander « qui fait quoi, avec quelle preuve ? » plutôt que « est-ce dans le cloud ? ».

Moindre privilège : juste les droits nécessaires

Le moindre privilège consiste à accorder uniquement les permissions nécessaires à une mission, pour la durée où elles sont nécessaires.

Le service commercial gère les commandes; les gestionnaires RH mettent à jour les dossiers du personnel; le comptable traite les factures. Donner tous les droits à tous simplifie parfois le travail immédiat mais augmente les conséquences d'une erreur ou d'un vol de compte. Les droits doivent être revus aux arrivées, changements de mission et départs. Les comptes d'administration restent réservés aux tâches qui les exigent.

Le stage terminé Le compte du stagiaire n'a plus besoin de lire les dossiers. Son responsable signale la fin de mission et l'accès est retiré puis vérifié.

À RETENIR Un droit doit avoir une raison, un responsable et une durée, pas seulement un titulaire.

Segmentation : limiter les chemins entre les zones

Segmenter consiste à séparer des ensembles de systèmes et à contrôler les communications nécessaires entre eux.

Les postes des utilisateurs ordinaires n'ont pas besoin d'atteindre directement l'administration des serveurs. Les échanges utiles sont permis; les autres sont bloqués selon des règles vérifiées. Un pare-feu applique des règles de communication, mais ne décide pas seul des droits métier. Une séparation dessinée ou un réseau nommé « sécurisé » ne prouve pas que les chemins sont réellement limités.

Du Wi-Fi aux factures

Un visiteur peut accéder au portail public sans pouvoir joindre le stockage interne des factures ni l'interface d'administration.

À RETENIR

Tester ce qui doit passer et ce qui doit être refusé, sans modifier la production hors mandat.

Défense en profondeur : interrompre puis limiter

Face à un message piégé, plusieurs mesures jouent à des moments différents. Leur complémentarité évite de dépendre d'une seule barrière.

- | | | |
|-----------|-----------------------------|--|
| 01 | Réduire l'entrée | Filtrer les messages et vérifier les demandes sensibles limitent les occasions de tromperie. |
| ↓ | | |
| 02 | Protéger l'accès | MFA et droits limités réduisent les possibilités d'abuser d'un compte volé. |
| ↓ | | |
| 03 | Limiter l'extension | Séparation des zones et des comptes d'administration freine la propagation. |
| ↓ | | |
| 04 | Détecter et contenir | Des traces exploitables et une procédure permettent de qualifier et de contenir sous mandat. |
| ↓ | | |
| 05 | Reprendre | Des copies protégées et une restauration testée permettent de rétablir un service fiable. |

À RETENIR Plusieurs outils identiques ne remplacent pas des protections complémentaires et effectivement testées.

3 · Comprendre les vulnérabilités et les faiblesses de sécurité

Un bug, un défaut de conception ou un mauvais réglage peuvent compromettre une protection. Leur présence ne prouve pas une attaque : il faut vérifier les conditions et les effets possibles.

À L'ISSUE DE CE CHAPITRE, VOUS SAUREZ...

- 1 Distinguer bug, faiblesse, mauvaise configuration, vulnérabilité et exploitation.
- 2 Expliquer la question à laquelle répond chaque référence.
- 3 Justifier une priorité à partir de preuves d'applicabilité et du besoin métier.

Un bug de sécurité : comparer l'attendu et le possible

Un bug est un défaut du logiciel. Il devient un problème de sécurité lorsqu'il permet de violer une propriété attendue, dans certaines conditions.

Le comportement attendu

Un client authentifié ne doit lire que ses propres factures. La règle porte sur chaque document demandé, pas seulement sur la connexion ou sur les boutons visibles.

Le comportement défectueux

Le serveur vérifie la connexion mais oublie de vérifier le propriétaire de la facture. Une demande portant sur une autre facture peut alors être acceptée : la confidentialité est menacée.

Conception ou réalisation

La règle peut avoir été oubliée dans la conception, ou mal traduite dans le code. Une erreur d'affichage isolée n'a pas nécessairement le même effet de sécurité.

À RETENIR

Décrire la règle attendue, les conditions du défaut et la propriété menacée avant de parler de gravité.

Faiblesse, vulnérabilité et exploitation

Le défaut, ses conditions concrètes et son utilisation ne doivent pas être confondus.

Faiblesse : le type de problème

Une règle de contrôle d'accès oubliée est une faiblesse de conception ou de réalisation. On peut la retrouver dans plusieurs logiciels différents, avec des conséquences différentes.

Vulnérabilité : un cas concret

Une version précise du portail laisse lire le dossier d'autrui dans certaines conditions. L'exploitation consiste à utiliser cette vulnérabilité. Sa présence ne démontre pas qu'une personne l'a déjà utilisée.

Le dossier hors périmètre

Un défaut peut permettre l'accès; il faut des traces et du contexte pour établir qu'un dossier a effectivement été lu.

À RETENIR

Présent, accessible et exploité sont trois affirmations qui demandent des preuves différentes.

Mauvaise configuration : un réglage peut exposer

Un logiciel à jour peut rester vulnérable si ses paramètres ne correspondent pas au besoin de protection. Corriger le code et corriger les réglages ne sont pas la même action.

Défaut logiciel

Le contrôle de permission fonctionne mal malgré un réglage correct. Le fournisseur doit corriger le mécanisme; l'équipe vérifie l'applicabilité et le résultat du correctif.

Mauvaise configuration

Le contrôle fonctionne, mais un dossier du personnel est partagé avec « tout le monde ». Il faut ajuster les permissions, vérifier les accès autorisés et refusés, puis surveiller les changements.

Le partage trop large

Mettre à jour le logiciel ne retire pas automatiquement un accès public. Retirer cet accès ne prouve pas non plus qu'aucune copie n'a été faite auparavant.

À RETENIR

Identifier la cause et son responsable : code, conception, paramètres ou procédure; vérifier la protection réelle.

Patch : corriger un défaut, puis vérifier le résultat

Un patch, ou correctif, est une modification fournie pour corriger un problème logiciel. Une mise à jour peut inclure plusieurs correctifs et d'autres changements.

Il faut connaître les logiciels présents, lire le bulletin de l'éditeur et identifier ceux qui sont concernés. La correction se prépare selon l'urgence : tests adaptés, sauvegarde ou retour arrière, déploiement, puis vérification de la version réellement utilisée et du service. Un correctif téléchargé n'est pas forcément installé; un programme peut encore fonctionner avec son ancienne version.

Le portail fictif

Le bulletin d'un portail de commandes annonce une correction de 1.2.3 vers 1.2.4. L'équipe vérifie la version active après le changement et teste une commande.

À RETENIR

Corrigé signifie « appliqué et vérifié », pas seulement « téléchargé ».

CWE : nommer une famille de faiblesse

CWE signifie Common Weakness Enumeration. Ce catalogue décrit des types de faiblesses logicielles et matérielles pour mieux les reconnaître et les éviter.

Une famille de faiblesse peut apparaître dans plusieurs produits. CWE-79 concerne une mauvaise neutralisation de contenu pouvant devenir actif dans une page web; CWE-89 concerne une entrée qui peut modifier une requête destinée à une base de données. L'intérêt n'est pas d'apprendre des numéros par cœur, mais de comprendre la cause pour prévenir sa répétition.

Une confusion de rôle

Si un champ de recherche devient une instruction pour la base au lieu de rester une valeur, la conception doit séparer données et instructions.

À RETENIR

CWE décrit un type de défaut, pas la gravité ni l'exploitation d'un produit chez nous.

CVE : une référence commune pour un cas public

CVE signifie Common Vulnerabilities and Exposures. Une référence CVE permet aux éditeurs, outils et équipes de parler de la même vulnérabilité publiée.

Un identifiant suit la forme CVE, une année et une suite numérique. Il relie une description et des références; il ne contient ni une note de gravité ni une correction. L'année n'indique pas le niveau d'urgence. Lire les produits, versions, conditions et bulletins associés reste indispensable. Une vulnérabilité non référencée peut aussi nécessiter une action.

Un ticket partagé

Une équipe recopie la référence exacte du bulletin dans son ticket pour éviter de confondre deux défauts du même logiciel. Nos cas fictifs seront nommés A et B, sans faux numéro officiel.

À RETENIR

La référence identifie le problème; elle ne prouve pas que notre installation est touchée.

CNA : qui attribue et publie une référence ?

CNA signifie CVE Numbering Authority : une organisation autorisée par le programme CVE à attribuer des identifiants dans un périmètre défini.

Des éditeurs, organismes ou équipes de recherche peuvent jouer ce rôle selon les règles du programme. Une CNA prépare et publie les informations relatives aux cas de son périmètre. Il ne faut pas imaginer qu'un seul organisme découvre, teste et corrige tous les défauts. Le bulletin de l'éditeur, l'enregistrement CVE et d'autres analyses apportent des informations complémentaires.

Des responsabilités distinctes

Un éditeur peut publier les versions affectées et le correctif; l'équipe d'exploitation vérifie ensuite les versions réellement déployées.

À RETENIR

Toujours demander qui produit une information, sur quel périmètre et à quelle date.

CVSS : la sévérité technique, pas tout le risque

CVSS signifie Common Vulnerability Scoring System. Ce système décrit les caractéristiques d'une vulnérabilité et produit un score de sévérité de 0 à 10.

Le score dépend de critères comme les conditions d'accès, les privilèges et les effets possibles. Il faut conserver la version du standard, le type de score, sa source et le vecteur, c'est-à-dire les valeurs des critères. Un score de base élevé décrit une sévérité technique; ce n'est ni un pourcentage de probabilité d'attaque ni une priorité locale automatique.

Une note de 9,8

« CVSS v3.1, base 9,8 » ne veut pas dire « 98 % de chance d'être attaqué ». Un service concerné mais isolé et un service exposé ne posent pas le même problème.

À RETENIR

Le score aide à comprendre le défaut; le contexte local aide à décider quoi faire.

CPE : nommer le produit et sa version

CPE signifie Common Platform Enumeration. C'est une nomenclature structurée pour désigner des classes de produits, logiciels et versions.

Elle aide les outils à rapprocher un inventaire et les conditions de produits mentionnées dans une analyse de vulnérabilité. Le nom comprend des informations comme le fournisseur, le produit et la version. Ce n'est pas le numéro unique d'un ordinateur de l'inventaire. Un nom ressemblant ou une version incomplète peut produire une mauvaise correspondance; le bulletin et l'installation réelle restent à vérifier.

Du nom commercial au produit

Un portail de commandes peut avoir plusieurs éditions. L'équipe précise l'éditeur, l'édition et la version avant de retenir une correspondance de produit.

À RETENIR

CPE aide à trouver des vulnérabilités candidates; il ne prouve pas seul leur applicabilité.

NVD : rassembler et enrichir les informations

NVD signifie National Vulnerability Database. Cette base du NIST, institut américain de normalisation et de technologie, enrichit des CVE déjà publiées.

La NVD rassemble des informations issues des descriptions, références et données publiques. Elle peut associer scores CVSS, familles CWE et conditions de produits CPE. Elle ne teste pas activement chaque vulnérabilité et ne regarde pas les machines de notre inventaire. L'enrichissement peut être incomplet, différé ou révisé; comparer sa date et son contenu au bulletin de l'éditeur.

Une fiche encore incomplète

Une CVE publiée sans score NVD reste un défaut à examiner. L'équipe lit les références disponibles plutôt que de conclure « pas de score, pas de risque ».

À RETENIR

Une base publique fournit du contexte; la vérification de notre installation reste locale.

EPSS : une estimation d'exploitation à trente jours

EPSS signifie Exploit Prediction Scoring System. Il estime la probabilité qu'une CVE publiée soit exploitée dans la nature dans les trente prochains jours.

Le modèle de FIRST publie un score entre 0 et 1, ainsi qu'un percentile de classement. Un score de 0,02 correspond à une estimation de 2 %; un percentile de 90 % indique un rang relatif, pas une probabilité de 90 %. L'estimation concerne la vulnérabilité dans l'ensemble observé, pas la probabilité de compromission d'une installation donnée. Il faut conserver la date.

Une estimation qui évolue

Un score faible aujourd'hui peut changer avec les signaux disponibles. Il ne supprime ni le défaut ni les conséquences si notre service est atteint.

À RETENIR

Probabilité estimée, rang relatif et risque local ne sont pas la même grandeur.

KEV : une exploitation déjà connue dans la nature

KEV signifie Known Exploited Vulnerabilities. Ce catalogue de la CISA, agence américaine de cybersécurité, recense des vulnérabilités dont l'exploitation est connue.

La présence dans KEV est un signal fort pour rechercher rapidement les installations concernées. Elle ne prouve pas que notre installation a subi l'attaque. L'absence du catalogue ne prouve pas qu'un défaut est inoffensif ou jamais exploité. Si un actif est affecté, il faut traiter son exposition et envisager aussi la recherche de traces : appliquer un correctif n'efface pas une intrusion passée.

Le portail public concerné

Une vulnérabilité applicable au portail apparaît dans KEV. L'équipe vérifie sa configuration, engage le traitement autorisé et examine les traces utiles.

À RETENIR

Exploitation connue ailleurs : agir sur l'applicabilité et la priorité, sans inventer un incident local.

SBOM : voir les composants derrière l'application

SBOM signifie Software Bill of Materials. C'est un inventaire structuré des composants logiciels et de leurs relations, rattaché à un produit ou une construction.

Une application peut intégrer des bibliothèques, c'est-à-dire du code réutilisable fourni par d'autres projets. Une SBOM aide à savoir si un composant est présent et dans quelle version. Sa date, son auteur et sa couverture comptent. Comme une liste d'ingrédients, elle rend le contenu plus visible; contrairement à une recette complète, elle ne décrit pas nécessairement tous les usages réels du logiciel.

La bibliothèque cachée

Le portail embarque un outil de lecture de documents. Son nom n'apparaît pas sur l'écran d'accueil, mais son inventaire permet de rechercher un avis le concernant.

À RETENIR

Composant présent ne signifie pas automatiquement vulnérabilité applicable ou déjà exploitée.

Exploit, PoC et patch : utiliser ou corriger un défaut

Lire une possibilité technique n'autorise pas à l'essayer sur un système réel.

Exploit et preuve de concept

Un exploit est une méthode ou du code qui utilise une vulnérabilité. Une PoC (Proof of Concept, preuve de concept) démontre une possibilité sous conditions. Elle peut être dangereuse, incomplète ou malveillante; sa publication ne prouve aucune attaque.

Patch : modifier le logiciel

Le correctif vise à supprimer ou réduire le défaut décrit. Il faut vérifier le produit, la version, les conditions d'application et le résultat. Une mesure temporaire, comme fermer une fonction, ne devient pas automatiquement une correction durable.

Lire sans exécuter Dans ce cours, les cas se résolvent sur papier. Aucun code trouvé sur Internet n'est à lancer pour « vérifier ».

À RETENIR

Une démonstration, une attaque observée et une correction vérifiée sont trois objets différents.

Applicabilité locale : sommes-nous vraiment concernés ?

Avant de prioriser, rapprocher l'avis et l'installation réelle. Une alerte d'inventaire n'est que le début de la vérification.

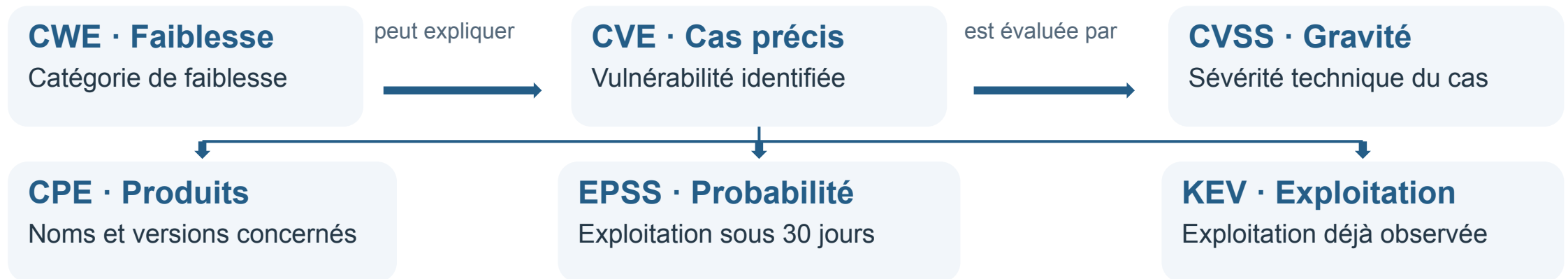
- | | | |
|-----------|----------------------------|--|
| 01 | Identifier | Produit, édition, composant et version réellement déployés : l'inventaire est-il récent ? |
| ↓ | | |
| 02 | Lire les conditions | Quelles versions, fonctions et configurations le bulletin déclare-t-il affectées ? |
| ↓ | | |
| 03 | Vérifier localement | Fonction présente, chemins d'accès, correctifs déjà appliqués ou rétroportés : quelles preuves ? |
| ↓ | | |
| 04 | Conclure et suivre | Concerné, non concerné avec justification, ou encore incertain : responsable, action et date de revue. |

À RETENIR Ne pas confondre « non applicable », « moins exposé » et « corrigé ».

Carte des vulnérabilités : des questions à relier

Chaque référence répond à une question. La priorité naît de leur lecture avec les preuves locales, pas de l'addition des scores.

1 · COMPRENDRE LE DOSSIER



2 · VÉRIFIER LOCALEMENT AVANT DE DÉCIDER



Présence, applicabilité, exposition et exploitation doivent être vérifiées séparément.

Exercice 4 · Cas A : le portail des commandes

SITUATION À ANALYSER

Cas entièrement fictif. Un portail de commandes en version 1.2.3 est exposé à Internet. Un bulletin indique que 1.2.3 avec import activé permet une lecture non autorisée; 1.2.4 corrige. L'inventaire actuel indique 1.2.3, import activé. Signaux pédagogiques : CVSS v3.1 base 7,5; EPSS 0,02, percentile 90 %; présent dans KEV. Aucune trace de vol n'est encore fournie.

- 01** L'applicabilité est-elle étayée ? Quelles observations relient le bulletin à l'installation ?
- 02** Que signifient EPSS 0,02 et percentile 90 % ? KEV prouve-t-il un vol local ?
- 03** Proposez une action prioritaire et une preuve de clôture du traitement.

Correction 4 · Applicable ne signifie pas déjà volé

Le produit, la version et la fonction indiqués dans le bulletin correspondent aux observations locales du cas A.

- | | | |
|-----------|-------------------------------|--|
| 01 | Comprendre les signaux | EPSS 0,02 signifie 2 % estimés, pas 90 %. Le percentile 90 % est un rang. KEV signale une exploitation connue ailleurs; il ne démontre ni un vol ni l'absence de vol sur cette installation. |
| 02 | Engager le traitement | Exposition publique, fonction affectée et exploitation connue justifient une action rapide. Faire appliquer le correctif ou une réduction temporaire d'exposition selon le mandat et examiner les traces utiles. |
| 03 | Vérifier la clôture | Confirmer la version active corrigée, tester le service et consigner les preuves avec le responsable. La recherche d'une exploitation antérieure reste distincte de la vérification du correctif. |

À RETENIR

Une urgence peut être justifiée sans inventer une certitude sur l'incident local.

Exercice 5 · Cas B : le logiciel de facturation

SITUATION À ANALYSER

Cas B fictif : un logiciel de facturation affiche 4.0; CVSS v3.1 base 9,8, EPSS 0,002, hors KEV. Il n'est pas accessible depuis Internet, mais les comptables l'utilisent en interne. Le fournisseur annonce un correctif rétroporté au paquet 4.0-r2; la preuve du paquet installé manque. L'échéance de paiement est demain. Cas A précédent : portail public affecté, exploitation connue, traitement engagé.

- 01** Peut-on déclarer B corrigé ou sans danger ? Quelles preuves manquent ?
- 02** Le 9,8 de B suffit-il à le placer automatiquement avant le 7,5 de A ?
- 03** Proposez une décision pour B avec responsable, action et condition de révision.

Correction 5 · Une priorité argumentée reste révisable

B demande une vérification locale urgente; ni la bannière « 4.0 » ni l'absence de KEV ne règlent le cas.

01 **Lever l'incertitude technique**

Vérifier le paquet installé et le bulletin du fournisseur. Si 4.0-r2 est effectivement appliqué et actif, documenter la correction rétroportée. La version affichée seule ne suffit pas.

02 **Comparer des contextes, pas des scores**

A combine exposition publique et exploitation connue. B a une forte sévérité et un enjeu métier immédiat. Hors KEV et faible EPSS ne rendent pas B sûre; 9,8 ne donne pas une priorité universelle.

03 **Faire décider et réexaminer**

Le responsable de la facturation et l'équipe technique valident vérification, traitement et continuité des paiements. Consigner une échéance et revoir la priorité si B est non corrigé ou si une activité suspecte apparaît.

À RETENIR

Une bonne décision indique ce qui la justifie aujourd'hui et ce qui la ferait changer demain.

4 · Pratiquer la gestion des risques cyber

Une protection est utile si elle réduit un scénario de dommage sans empêcher inutilement le service. Le choix doit être expliqué, vérifié et révisé.

À L'ISSUE DE CE CHAPITRE, VOUS SAUREZ...

- 1 Relier accès, sauvegardes, correctifs et segmentation à des besoins.
- 2 Distinguer menace, vulnérabilité, exposition et risque.
- 3 Proposer une décision proportionnée, avec responsable et preuve.

Menace, vulnérabilité, exposition : ne pas confondre

Ces notions décrivent des éléments différents d'un scénario de dommage.

Menace : ce qui pourrait nuire

Une tentative de fraude, un rançongiciel ou une panne peuvent menacer le service. Il faut préciser l'événement redouté : détourner un paiement, perdre des dossiers du personnel ou arrêter le traitement des commandes.

Faiblesse et chemin d'accès

Une vulnérabilité est une faiblesse exploitable ou susceptible de contribuer au dommage : logiciel non corrigé, droits excessifs, validation absente. L'exposition décrit la possibilité d'atteindre la cible, par Internet, un compte ou un tiers.

La facture détournée

La fraude est la menace; l'absence de seconde validation est une faiblesse; le courriel au comptable ouvre un chemin de contact.

À RETENIR

Une faiblesse présente ne prouve pas qu'une attaque a eu lieu.

Du scénario au risque : poser les bonnes questions

Le risque associe un scénario possible et ses conséquences, dans un périmètre et une période définis.

- | | | |
|-----------|------------------------------|--|
| 01 | Définir le besoin | Quel service et quelles personnes pourraient être touchés ? |
| ↓ | | |
| 02 | Décrire le scénario | Quelle cause profiterait de quelle faiblesse et par quel chemin ? |
| ↓ | | |
| 03 | Apprécier le risque | Quelle vraisemblance sur la période retenue, quels impacts et quelles incertitudes ? |
| ↓ | | |
| 04 | Choisir un traitement | Qui décide des mesures, de leur délai et du risque qui restera ? |
| ↓ | | |
| 05 | Vérifier et réviser | Quelles preuves montrent l'efficacité ? Quand réexaminer la décision ? |

À RETENIR Un risque s'explique en phrases avant de se résumer dans une couleur ou un nombre.

Probabilité et impact : des estimations, pas des certitudes

La probabilité estime la possibilité d'un scénario sur une période. L'impact décrit le dommage s'il survient. Les deux doivent être justifiés.

« Probabilité × impact » peut aider dans un modèle défini, mais les chiffres ne créent pas de certitude. Une probabilité annuelle de 10 % et une perte unique de 20 000 € donnent une perte attendue de 2 000 € par an dans ce modèle simplifié. Ce n'est ni une facture certaine ni une perte maximale. Des niveaux 1 à 5 sont des rangs : 4 n'est pas deux fois 2.

Un classement prudent

L'échéance de paiement peut rendre une panne de facturation plus grave aujourd'hui que demain. Un classement sans date ni besoin métier masque cette différence.

À RETENIR

Expliquer les hypothèses et les incertitudes; ne pas additionner des nombres qui n'ont pas le même sens.

Traiter le risque et suivre ce qui reste

Traiter un risque, c'est décider comment agir sur le scénario ou ses conséquences. Le risque résiduel est celui qui reste après les mesures réellement appliquées.

On peut éviter une activité, réduire le risque, partager certaines conséquences ou accepter un risque selon la gouvernance prévue. Une assurance ne supprime ni l'incident ni toutes les responsabilités. La décision indique le responsable, les actions, les preuves attendues et la date de revue. L'équipe de sécurité éclaire l'arbitrage; elle n'accepte pas seule un risque métier au nom de tous.

Le changement bancaire

Un rappel au fournisseur et une seconde validation réduisent la fraude. Un contact compromis ou une fraude interne restent possibles : la décision n'est pas « risque zéro ».

À RETENIR

Une décision de risque appartient à un responsable identifié et doit pouvoir être réexaminée.

Sauvegarde et réplication : deux réponses différentes

Une copie n'est utile à la reprise que si elle reste accessible, exploitable et suffisamment indépendante de la panne.

Réplication : maintenir une copie proche

Elle propage les changements vers une autre copie pour améliorer certains besoins de disponibilité. Elle peut aussi propager très vite une suppression, une erreur ou un chiffrement malveillant.

Sauvegarde : retrouver un état

Elle conserve des états récupérables selon une politique définie. Des copies séparées et protégées limitent la possibilité de tout détruire avec les mêmes droits. Il faut aussi disposer des clés, logiciels et procédures nécessaires à la restauration.

Le dossier supprimé

Si la suppression est recopiée partout, il faut retrouver une version antérieure protégée, pas seulement changer de serveur.

À RETENIR

Le résultat attendu n'est pas « une copie existe », mais « nous pouvons restaurer un service fiable ».

Restaurer : vérifier les données et le service

Restaurer consiste à rétablir un état utilisable à partir de copies et de procédures. La réussite se mesure par le service rendu, pas seulement par le retour de fichiers.

Le métier fixe la perte de données et l'interruption acceptables. On prépare un environnement de reprise, on récupère données et dépendances, puis on teste une action réelle. La durée observée et l'âge des données sont comparés au besoin. Une copie récente n'est pas forcément saine : il faut vérifier ce qui a provoqué l'incident avant de remettre en service.

La commande test

Après reprise, le service commercial retrouve un dossier connu et vérifie qu'il peut enregistrer puis relire une nouvelle commande autorisée.

À RETENIR

Tester une restauration avant l'urgence révèle ce qu'un rapport de sauvegarde ne dit pas.

Exercice 6 · La sauvegarde verte suffit-elle ?

SITUATION À ANALYSER

Le portail de commandes est sauvegardé chaque nuit à minuit. Lundi à 16 h, les dossiers deviennent inutilisables. La dernière copie saine disponible date de lundi 0 h. Le responsable du service accepte au maximum deux heures de saisies perdues. Le rapport indique « sauvegarde réussie », mais aucune restauration complète n'a été testée.

- 01** Quelle période de saisies risque d'être perdue ? Le besoin de deux heures est-il couvert ?
- 02** Que faut-il tester avant de déclarer la reprise réussie ?
- 03** Pourquoi le rapport vert ne suffit-il pas à promettre un délai de retour ?

Correction 6 · Une capacité doit être démontrée

La sauvegarde réussie est une information utile; elle ne démontre ni une perte acceptable ni une reprise complète.

01 Constater l'écart

Sans autre copie exploitable, les saisies entre 0 h et 16 h sont à risque : jusqu'à seize heures, au-delà des deux heures acceptées. Il faut revoir la capacité avec le responsable du service.

02 Prouver l'usage

Restaurer dans un périmètre contrôlé, vérifier les dossiers et les droits, puis créer et relire une commande test. Mesurer la durée et consigner les erreurs rencontrées.

03 Ne pas promettre sans mesure

Le rapport décrit la sauvegarde, pas la vitesse de remise en service. Des clés manquantes, des dépendances oubliées ou une copie altérée peuvent empêcher la reprise.

À RETENIR

Comparer le besoin métier à une restauration observée, pas à une simple intention.

Exercice 7 · Payer sans fermer les yeux

SITUATION À ANALYSER

Un service financier doit payer 20 000 € demain pour maintenir un service utile au traitement des commandes. Un courriel du fournisseur demande un nouveau compte bancaire. Le changement peut être légitime. Une seule personne peut modifier puis approuver le virement; aucune vérification indépendante n'est encore faite.

- 01** Formulez le scénario de risque avec menace, faiblesse et conséquence.
- 02** Proposez deux contrôles et la preuve que chacun a été appliqué.
- 03** Qui arbitre le délai si le bénéficiaire reste incertain, et quel risque subsiste ?

Correction 7 · Vérifier et faire arbitrer le paiement

Le risque est le détournement d'un virement, facilité ici par une modification non vérifiée et une validation unique.

01 Deux contrôles complémentaires

Rappeler le fournisseur via un numéro déjà connu, puis faire approuver le changement par une seconde personne habilitée. Conserver la confirmation et la trace d'approbation selon la procédure.

02 Une décision métier

Si le bénéficiaire reste incertain, suspendre l'exécution et escalader au responsable du paiement. Il arbitre le délai et les solutions de secours; l'analyste documente, sans accepter seul le risque.

03 Un risque encore présent

Un contact ou un compte interne peut être compromis. Vérifier l'application des contrôles, suivre le paiement et prévoir une revue; deux validations purement automatiques ne suffisent pas.

À RETENIR

Une protection utile rend la décision plus fiable sans oublier l'activité à maintenir.

5 · Les acteurs de la menace et le cadre réglementaire

Comprendre les capacités, les intentions et les chemins d'attaque aide à protéger sans désigner trop vite un coupable. Le cadre juridique définit aussi ce que nous sommes autorisés à collecter, vérifier et signaler.

À L'ISSUE DE CE CHAPITRE, VOUS SAUREZ...

- 1 Distinguer autorisation, niveau technique et intention.
- 2 Reconnaître les mécanismes du phishing et du rançongiciel sans inventer une attribution.
- 3 Identifier le contexte juridique et les responsables compétents avant d'agir.

Acteurs de menace : des capacités différentes

De méthodes simples à des campagnes plus complexes : une échelle illustrative, pas un classement des dommages.

MOINS COMPLEXE

01 Script kiddies

Utilisent des outils prêts à l'emploi, souvent sans bien comprendre leurs mécanismes.

02 Attaquants opportunistes

Adaptent des méthodes connues aux cibles accessibles et aux occasions rencontrées.

03 Criminels organisés

Peuvent coordonner des spécialistes, répartir les tâches et industrialiser leurs opérations.

PLUS COMPLEXE

04 APT

Mobilisent des ressources dans la durée et adaptent leurs campagnes pour poursuivre un objectif.

Menace interne :
transversale

Un accès de confiance peut être abusé à tout niveau de complexité.

À RETENIR

Une attaque simple peut causer de graves dommages; observer les capacités et les faits, pas seulement l'étiquette.

Hacker autorisé ou script kiddie : quel mandat ?

Le savoir-faire ne donne pas le droit d'agir sur le système d'autrui.

Hacker autorisé

Un hacker explore le fonctionnement des systèmes. Avec un mandat explicite, un périmètre et des limites convenues, cette exploration peut aider à trouver des défauts. Une bonne intention ne remplace pas l'autorisation.

Script kiddie

Ce terme informel désigne une personne qui utilise des outils prêts à l'emploi sans bien les comprendre. Elle peut provoquer des dégâts importants. Le terme ne prouve ni son âge, ni son objectif, ni la légalité de ses actes.

Un portail public

Tester un outil sur le portail public « pour aider » sans accord n'est pas un exercice autorisé.

À RETENIR

Avant un test : autorisation, cible, limites et canal de signalement doivent être définis.

APT : une menace organisée dans la durée

APT signifie Advanced Persistent Threat, ou menace persistante avancée : des moyens et des actions suivies sont mobilisés pour atteindre un objectif durable.

Un acteur peut adapter ses méthodes, revenir après un blocage et chercher à conserver un accès discret. L'objectif peut être l'espionnage ou le sabotage. Une campagne organisée ne recourt pas forcément à une technique spectaculaire : un mot de passe volé peut suffire. Le terme ne signifie pas automatiquement « État » et ne doit pas devenir une étiquette pour toute attaque.

Observer sans attribuer

Des accès répétés à des dossiers de recherche et développement méritent une analyse. Leur répétition seule ne permet pas de nommer le groupe responsable.

À RETENIR

Décrire d'abord l'activité observée; l'attribution demande beaucoup plus de preuves.

Menace interne : un accès légitime peut être abusé

Un insider est une personne disposant d'un accès interne ou de confiance : salarié, prestataire ou partenaire. Cet accès peut contribuer à un dommage.

Le dommage peut être volontaire, comme une copie interdite de dossiers, ou lié à une négligence. Un salarié peut aussi subir le vol de son compte : l'activité de ce compte ne prouve alors pas sa culpabilité. Protéger suppose des droits adaptés, des contrôles et un signalement possible sans blâme, pas une suspicion générale envers le personnel.

L'ancien prestataire

Son compte de maintenance reste actif après son départ. Le danger vient d'un accès devenu inutile, même avant toute preuve d'utilisation malveillante.

À RETENIR

Le statut « interne » ne dispense ni de limiter les droits ni de vérifier les faits.

Motivations : ce qui est recherché change le risque

Une motivation est un objectif supposé : gagner de l'argent, obtenir des informations, perturber une activité ou nuire à sa réputation.

La fraude détourne une opération, l'extorsion fait pression pour obtenir quelque chose, l'espionnage cherche des informations et le sabotage vise une perturbation. Ces objectifs peuvent se combiner. Ils orientent les vérifications, mais une hypothèse de motivation reste à confirmer. Une panne peut produire le même effet visible qu'un sabotage.

La même facture, deux usages

La voler peut préparer une fraude au paiement ou révéler des relations commerciales. Le document seul ne dit pas quel objectif était poursuivi.

À RETENIR

Relier objectif, information et dommage; ne pas déduire l'auteur d'un effet visible.

Phishing : détourner la confiance pour faire agir

Le phishing, ou hameçonnage, est une tromperie destinée à faire révéler une information, ouvrir un fichier ou réaliser une action au profit de l'attaquant.

Le message joue souvent sur l'urgence, l'autorité ou une situation familière. Il peut arriver par courriel, messagerie ou téléphone, et provenir d'un compte compromis. Un logo, un français impeccable ou une adresse connue ne suffisent pas à le valider. Pour une demande sensible, retrouver un contact ou un portail connu indépendamment du message reçu.

Une facture « urgente »

Le faux fournisseur demande de changer le compte bancaire avant le prochain virement. Le comptable appelle le numéro du dossier fournisseur, pas celui du message.

À RETENIR

Vérifier la demande par un canal indépendant; ne pas se contenter d'inspecter son apparence.

Ransomware : bloquer, parfois voler, puis extorquer

Un ransomware, ou rançongiciel, est un logiciel malveillant qui peut chiffrer des fichiers pour les rendre inutilisables et demander une rançon.

Le chiffrement transforme des données en un contenu illisible sans le secret adapté. Des attaquants volent parfois les fichiers avant de les bloquer, puis menacent de les publier. Une sauvegarde peut aider à reprendre, mais n'annule pas une fuite. Un fichier devenu illisible ne suffit pas, à lui seul, à prouver un rançongiciel : une panne ou une corruption restent possibles.

Le traitement des commandes arrêté

Les dossiers de commande ne s'ouvrent plus et une demande de paiement apparaît. Le service commercial signale immédiatement; la réponse coordonnée vérifie le périmètre touché.

À RETENIR

Ne pas improviser paiement, nettoyage ou redémarrage : alerter et suivre la procédure de réponse.

Une attaque possible : du message au dommage

Ce chemin illustre un scénario, pas une suite obligatoire pour toutes les attaques.

- | | | |
|-----------|----------------------------|--|
| 01 | Tromper | Un message imite un portail professionnel et demande une connexion urgente. |
| ↓ | | |
| 02 | Obtenir un accès | La victime saisit son secret sur une fausse page; l'attaquant tente de le réutiliser. |
| ↓ | | |
| 03 | Abuser des droits | Si l'accès réussit, les permissions du compte déterminent ce qui devient accessible. |
| ↓ | | |
| 04 | Produire un dommage | Des dossiers peuvent être copiés, modifiés ou bloqués; il faut des preuves pour savoir lesquels. |

À RETENIR Un clic ne prouve pas que toutes les étapes ont réussi; chaque étape offre une possibilité de protection.

Règles juridiques : commencer par le contexte

Les règles dépendent des pays, des personnes, des activités, des données et des contrats concernés. Un cours général ne remplace pas un avis compétent.

Le RGPD, Règlement général sur la protection des données, illustre un cadre européen dont le champ territorial doit être vérifié, y compris pour certaines activités hors Union européenne. La collecte de traces, leur durée, les accès et les notifications doivent être encadrés. Un accès technique à un outil ne donne pas le droit d'examiner tous les dossiers ou de tester n'importe quelle cible.

Une demande d'enquête

Avant d'exporter les courriels d'un salarié, l'analyste vérifie le mandat, la finalité, le périmètre et les responsables autorisant cette collecte.

À RETENIR

L'autorisation, la proportionnalité et la protection des personnes accompagnent toute action technique.

6 · Les comportements rationnels en cybersécurité

Agir rationnellement, c'est vérifier une demande, distinguer faits et hypothèses, puis choisir une action proportionnée à son mandat. Ces réflexes valent pour chaque utilisateur et pour l'analyste SOC.

À L'ISSUE DE CE CHAPITRE, VOUS SAUREZ...

- 1 Vérifier une demande sensible sans céder à l'urgence ni accuser sans preuve.
- 2 Distinguer événement, alerte et incident à partir de faits et d'hypothèses vérifiables.
- 3 Signaler et préparer une escalade exploitable sans dépasser son mandat.

Raisonner : chercher ce qui pourrait nous contredire

Un raisonnement fiable sépare les faits, les explications possibles et la décision. Il vérifie aussi l'hypothèse qui ne nous plaît pas.

Le biais de confirmation pousse à retenir seulement les indices compatibles avec notre première idée. Une activité inhabituelle peut être malveillante, mais aussi venir d'une maintenance ou d'une erreur. Vérifier la source, l'heure et le contexte, puis rechercher une observation qui départagerait les hypothèses. L'action doit être proportionnée au dommage possible et au mandat.

Le portail indisponible

Avant de conclure au sabotage, vérifier aussi le changement prévu, l'alimentation et les dépendances. Cela n'interdit pas une escalade rapide si l'impact est important.

À RETENIR

Dire ce que l'on sait, ce que l'on suppose et ce qui ferait changer d'avis.

Exercice 8 · Le directeur demande une exception

SITUATION À ANALYSER

Un courriel portant le nom du directeur demande au service commercial d'envoyer tous les dossiers de commande vers une nouvelle adresse « avant ce soir ». Le texte est impeccable et affirme : « Je suis en réunion, ne téléphonez pas ». Une collègue a déjà ouvert le message, sans autre action.

- 01** Quels éléments justifient une vérification, sans prouver une attaque ?
- 02** Comment vérifier et que faut-il éviter de transmettre ?
- 03** Que demander à la collègue, et que peut-on affirmer sur son poste ?

Correction 8 · Vérifier la demande, pas le logo

L'urgence, l'envoi massif et l'interdiction d'appeler rendent la demande inhabituelle; ce ne sont pas une preuve définitive.

- | | | |
|-----------|--------------------------------------|--|
| 01 | Reprendre un canal connu | Joindre le directeur ou son délégataire par l'annuaire interne ou un canal déjà établi. Ne pas utiliser les coordonnées ni le lien fournis dans le message suspect. |
| 02 | Protéger et signaler | Ne pas envoyer les dossiers pour « voir ». Transmettre le contexte au canal de signalement prévu, avec l'heure, la demande et les actions réalisées; limiter les données personnelles jointes. |
| 03 | Ne pas accuser ni surconclure | Demander si la collègue a suivi un lien, saisi un secret ou exécuté un fichier. L'ouverture rapportée seule ne prouve pas une compromission. Suivre les vérifications de l'équipe compétente. |

À RETENIR	Un signalement rapide et précis est plus utile qu'un verdict hâtif ou une recherche de coupable.
------------------	--

SOC : une équipe, des procédures et des outils

SOC signifie Security Operations Center, centre opérationnel de sécurité. Il surveille un périmètre défini, analyse les signaux et contribue à la réponse aux incidents.

Ses analystes rapprochent des traces, les besoins métier et les procédures. Ils cherchent ce qui s'est passé, ce qui reste incertain et qui doit agir. Le SOC peut être interne, externalisé ou partagé. Un écran plein d'alertes ne constitue pas à lui seul une capacité de surveillance : il faut des sources fiables, des personnes disponibles et une chaîne de décision.

Une messagerie professionnelle

Une alerte de connexion inhabituelle devient utile si l'équipe sait quel compte et quel service elle concerne, comment vérifier et à qui transmettre.

À RETENIR

Le résultat attendu est une décision explicable et suivie, pas un volume d'alertes.

Événement, alerte, incident : trois niveaux de lecture

Observer quelque chose, demander une vérification et qualifier un incident sont trois opérations différentes.

Événement et alerte

Un événement est une occurrence observable : connexion, refus d'accès, modification. Une alerte est un signal demandant une analyse, issu d'une règle, d'un outil ou d'un signalement humain. Elle peut correspondre à une activité légitime.

Incident

Un incident correspond à une atteinte ou une menace imminente à la sécurité selon les critères de l'organisation, justifiant une réponse. Il peut provenir d'une attaque, d'une erreur ou d'une autre cause; il n'exige pas toujours une preuve d'attaquant identifié.

La facture supprimée

Une suppression accidentelle peut devenir un incident si elle affecte le service. Une alerte de connexion peut, elle, être expliquée par un déplacement.

À RETENIR

Ni toutes les alertes ne sont des incidents, ni tous les incidents ne sont des attaques.

Lire un log : les faits ont une source et des limites

Un log, ou journal, enregistre des événements vus par un système. Il aide à reconstruire les actions, mais ne raconte pas automatiquement toute l'histoire.

Chercher la source, l'heure et son fuseau, l'équipement, le compte, l'action, la ressource et le résultat. « Connexion refusée » n'est pas « accès réussi ». Un compte n'est pas forcément l'humain attendu. Une trace absente peut venir d'une collecte incomplète. Protéger les journaux et leurs accès; ne pas y recopier mots de passe, jetons de session ou données personnelles inutiles.

Fait, hypothèse, vérification

Fait : le journal annonce un export par compte-commandes. Hypothèses : export prévu ou compte compromis. Vérification : rapprocher demande métier, session et traces d'accès.

À RETENIR

Conserver la provenance et distinguer explicitement observation, hypothèse et conclusion.

Avant, BANG, après : surveiller en continu

BANG est un repère pédagogique de début d'attaque, pas l'heure de détection. La surveillance existe avant et après.

AVANT · PRÉVENTION

Réduire la probabilité et les effets d'une attaque

APRÈS · RÉACTION

Limiter les dégâts et reprendre l'activité



BANG

Préparer · durcir · former

Qualifier · contenir · rétablir · apprendre

SURVEILLANCE CONTINUE

Collecter les traces, observer et détecter avant, pendant et après.

Attaque ≠ détection : la réaction peut commencer pendant que l'attaque se poursuit.

Prévenir, détecter, répondre et reprendre se complètent; les actions ne sont pas confinées à un instant.

Du signal à la décision : une alerte doit être suivie

Le traitement relie les observations à une action autorisée, puis vérifie ce que cette action a changé.

- | | | |
|-----------|-------------------------------|--|
| 01 | Recevoir et situer | Quelle source, quel actif, quel compte, quelle heure et quel service métier ? |
| ↓ | | |
| 02 | Qualifier | Quels faits sont confirmés ? Quelles explications légitimes ou malveillantes restent possibles ? |
| ↓ | | |
| 03 | Prioriser et escalader | Quel impact possible, quelle urgence, quel destinataire selon la procédure ? |
| ↓ | | |
| 04 | Agir sous mandat | Appliquer ou faire appliquer les actions approuvées; conserver leur justification et leurs effets. |
| ↓ | | |
| 05 | Vérifier et apprendre | Confirmer le résultat, documenter la clôture ou poursuivre; améliorer les contrôles et la détection. |

À RETENIR

Une alerte n'est pas traitée parce qu'elle a été masquée : la décision et son résultat doivent être tracés.

L1 : qualifier et transmettre sans dépasser son rôle

L1 signifie niveau 1 : c'est le premier niveau d'analyse dans une organisation qui utilise ce découpage. Son périmètre est défini par les procédures.

L'analyste L1 vérifie le contexte de l'alerte, rassemble les faits utiles, applique les vérifications autorisées et documente les incertitudes. Il escalade vers le bon interlocuteur si la gravité, le doute ou l'action requise dépasse son mandat. Un transfert utile contient le service concerné, les preuves, les hypothèses, les actions déjà faites et la décision attendue.

Le compte de facturation

Une session inhabituelle touche un compte pouvant préparer des virements. Le L1 signale l'enjeu et les preuves; il ne bloque pas seul tous les paiements sans procédure.

À RETENIR

Escalader est une action professionnelle quand la décision dépasse le mandat ou les preuves disponibles.

Exercice 9 · Préparer une escalade utile

SITUATION À ANALYSER

Traces fictives de commandes-01, même jour, heures UTC : 08:42, compte commandes, connexion refusée; 08:43, même compte, connexion réussie; 08:45, export de 240 dossiers. Une alerte « export inhabituel » est ouverte. Le service commercial indique qu'un export mensuel était prévu, mais ne confirme ni ce compte ni cette heure. Vous êtes L1, autorisé à consulter les traces et à escalader, pas à bloquer le portail.

- 01** Rédigez deux faits et deux hypothèses; qu'est-ce qui reste non établi ?
- 02** Quelles vérifications permettraient de distinguer les hypothèses ?
- 03** Écrivez une escalade courte : impact possible, preuves, limites et décision attendue.

Correction 9 · Un export à qualifier, pas un coupable

Les sources rapportent une connexion et un export; ni la légitimité précise ni une fuite externe ne sont encore établies.

- | | | |
|-----------|--|--|
| 01 | Séparer les niveaux de certitude | Faits : connexion réussie à 08:43 et export de 240 dossiers à 08:45 selon commandes-01. Hypothèses : export mensuel autorisé ou usage abusif du compte. L'échec précédent ne prouve pas une intrusion. |
| 02 | Vérifier sans élargir le mandat | Faire confirmer la demande, le compte, l'heure et le périmètre autorisés. Rapprocher la session et les traces d'export disponibles; vérifier source et horodatage. Ne pas collecter des contenus sans nécessité. |
| 03 | Transmettre une décision attendue | « Export inhabituel de 240 dossiers; autorisation non confirmée. Traces jointes, pas de blocage effectué. Merci de qualifier la légitimité et de décider des mesures de protection selon la procédure. » |

À RETENIR

La qualité d'une escalade vient de faits précis, de limites explicites et d'une demande de décision.

Synthèse : protéger une activité en raisonnant

Les bases servent à relier un besoin humain, un fonctionnement technique, des observations et une décision proportionnée.

- | | | |
|-----------|-------------------------------|--|
| 01 | Partir de l'activité | Commandes, dossiers du personnel, messagerie, factures : qui dépend de quoi et quand ? |
| ↓ | | |
| 02 | Décrire le besoin | Confidentialité, intégrité, disponibilité, traçabilité et respect des personnes. |
| ↓ | | |
| 03 | Comprendre le scénario | Cause possible, faiblesse, accès, protections et conséquences; ne pas confondre défaut et attaque. |
| ↓ | | |
| 04 | Vérifier les faits | Sources, applicabilité, traces et hypothèses concurrentes; signaler ce qui reste inconnu. |
| ↓ | | |
| 05 | Décider et suivre | Responsable, action autorisée, preuve du résultat et revue : la sécurité est un travail continu. |

À RETENIR La suite approfondit l'analyse SOC puis l'architecture et Wazuh; ces bases donnent le sens des gestes à venir.

Le quotidien du SOC Analyst

En séance : méthode, SSH, phishing et ransomware.
Les autres scénarios restent accessibles en approfondissement.

72 diapositives sources conservées · Le programme source ne fixe pas le calendrier actuel.

Le SOC Analyst

Quotidien et art de l'investigation

Une formation blue team : raisonner, utiliser les référentiels et évaluer les malwares. Les exercices dans le navigateur utilisent des preuves synthétiques ; les outils réels exigent un lab distinct encadré.

AUTEUR : TOUHAMI KASBAOUI

Programme du support source

01 **Le SOC et votre rôle**
Rythme quotidien, niveaux d'analystes, compétences et outils de travail.

02 **Référentiels adverses**
Cyber Kill Chain, MITRE ATT&CK et pyramide de la douleur.

03 **Familles de malwares**
Leur nature, leur propagation et leurs actions après l'intrusion.

04 **La démarche d'investigation**
La boucle du triage à la réponse, appliquée dans chaque scénario.

Un SOC surveille les systèmes d'une organisation en continu pour détecter les menaces, enquêter et y répondre.



Détecter

Transformer une masse de logs en une courte liste d'éléments à examiner.



Enquêter

Établir les faits : attaque réelle ou bruit ?
Quelle est son étendue ?



Répondre

Contenir, éradiquer, rétablir — puis enrichir la détection avec les enseignements tirés.

Niveaux et responsabilités des analystes

NIVEAU 1

Analyste de triage

Examine les alertes en premier. Évalue les preuves, consigne les incertitudes, enrichit et escalade. Agit dans les limites de son mandat.

- Surveiller alertes et tableaux de bord
- Triage initial et enrichissement
- Ouvrir et documenter les dossiers

NIVEAU 2

Analyste de réponse à incident

Reçoit les escalades et approfondit l'enquête. Délimite l'incident et pilote son confinement.

- Analyse approfondie
- Périmètre et confinement
- Corrélation entre hôtes

NIVEAU 3

Threat Hunter / Expert

Recherche proactive, investigation numérique, analyse de malwares et création des détections utilisées par l'équipe.

- Threat hunting proactif
- Investigation et rétro-ingénierie
- Ingénierie de détection

Une journée (ou une nuit) dans la file

Le travail est une boucle, pas une liste à cocher. Le même cycle se répète pour chaque alerte, des dizaines de fois par vacation.



La fatigue liée aux alertes est réelle. La plupart ne sont pas des incidents : chacune mérite un examen rigoureux, sans épuiser l'analyste.

Les qualités d'un bon analyste L1

Analyse des logs et données

Lire les logs d'authentification, web, DNS et endpoint ; repérer l'anomalie parmi des milliers de lignes.

Bases réseau

Ports, protocoles, DNS, HTTP, TCP/IP : reconnaître un fonctionnement normal.

Mécanismes des OS

Processus, services, registre, authentification Linux et cachettes des attaquants (logique des stealers).

Raisonnement adverse

Se demander : « À leur place, que ferais-je ensuite ? » Les référentiels vous y aident.

Documentation claire

Un dossier vaut par sa rédaction : preuves, chronologie et décision sont essentielles.

Curiosité et sang-froid

Suivre la piste un peu plus loin ; garder son calme face à une alerte « critique ».

Les outils à votre disposition

Exemple de chaîne SOC, non déployée avec l'application. Les labs navigateur utilisent des données synthétiques ; l'usage réel exige une installation et des accès distincts.

Wazuh SIEM / XDR

Collecte les logs, applique les règles et produit les alertes à trier.

TheHive GESTION DES DOSSIERS

Centralise tâches, observables, chronologie et compte rendu de votre travail.

Cortex ANALYSEURS

Enrichit un hash, une IP ou une URL via VirusTotal, AbuseIPDB et d'autres sources.

MISP RENSEIGNEMENT

Renseignement partagé avec source, date et confiance — pas une liste définitive d'acteurs malveillants.

OpenCTI CONNAISSANCE CTI

Relie les indicateurs aux malwares, outils et acteurs de la menace.

Shuffle SOAR

Automatise les tâches courantes en reliant les outils entre eux.

Où trouver les preuves

Les preuves comprennent logs, signalements et artefacts. Les lacunes de collecte limitent les conclusions d'une recherche.

Endpoints Windows

- Logs Security / System / App
- **Télémétrie détaillée avec Sysmon**
- PowerShell (4104 : blocs de script)

Endpoints Linux

- auth.log / secure
- **auditd · syslog / journald**
- Sysmon pour Linux

Réseau

- Pare-feu · DNS · proxy
- IDS — Suricata · métadonnées Zeek
- NetFlow

Web et applications

- Logs access et error Apache / Nginx
- Logs applicatifs
- Logs de bases de données

Identité et cloud

- Logs Active Directory / DC
- VPN et accès distant
- Traces d'audit cloud (O365...)

Le principe

La visibilité avant les règles : une lacune de collecte est une lacune de détection.

Télémétrie endpoint : voir au plus près

Sysmon et auditd

Les logs ordinaires disent « une connexion a eu lieu ». La télémétrie endpoint précise le processus, son parent et sa destination : essentiel contre les attaques fileless et Living off the Land.

Windows · Sysmon

EID 1 Création de processus et commande complète

EID 3 Connexions (activer EID 3)

EID 11 Création de fichier

EID 13 Écriture d'une valeur du registre

EID 10 Accès à un processus (ex. LSASS)

17/18 Tubes nommés · 22 : requêtes DNS

Linux · auditd + Sysmon

- **Règles auditd execve : tentatives d'exécution**
- Surveillance : passwd, authorized_keys
- auth.log / journal : SSH, sudo, PAM
- **Sysmon Linux : sous-ensemble pris en charge**
- Corréler session, processus et résultat

Prérequis : activer les événements, les règles d'audit et la collecte. L'absence de télémétrie ne prouve pas l'absence du comportement.

Les référentiels structurent le chaos et donnent un langage commun à l'équipe.

Structure

Une attaque comporte des étapes. Les nommer permet de savoir où l'on se situe.

Anticipation

Connaître la suite habituelle aide à chercher les preuves pertinentes.

Langage commun

« T1110 : Brute Force, Credential Access » désigne un comportement commun aux analystes — pas un verdict.

La Cyber Kill Chain

Modèle d'intrusion en sept étapes : un cadre utile, pas une séquence obligatoire pour chaque attaque.



Comment l'utiliser concrètement



Cartographier les observations étayées

Une tâche peut soutenir l'hypothèse d'une installation. Un échec de connexion seul ne prouve ni étape de la Kill Chain ni compromission.



Regarder dans les deux sens

À l'étape 5, chercher les traces des étapes 1 à 4 (comment sont-ils entrés ?) et anticiper les étapes 6 et 7.



Rompre la chaîne au plus tôt

Arrêter l'attaquant à la première étape visible : chaque étape empêchée réduit les dommages.

MITRE ATT&CK

attack.mitre.org

Catalogue évolutif et communautaire de comportements adverses réels, classés en tactiques (objectif) et techniques (méthode).

LE POURQUOI

Tactiques

Objectifs : accès initial, persistance, accès aux identifiants, mouvement latéral, exfiltration, impact... Vérifier la version de la matrice.

LE COMMENT

Techniques

Méthode employée pour atteindre l'objectif, avec un ID comme T1566 et souvent des sous-techniques comme T1566.001.

Son intérêt : relier une observation à un comportement connu, orienter les recherches suivantes et partager les mêmes identifiants entre équipes.

Techniques présentes dans les scénarios

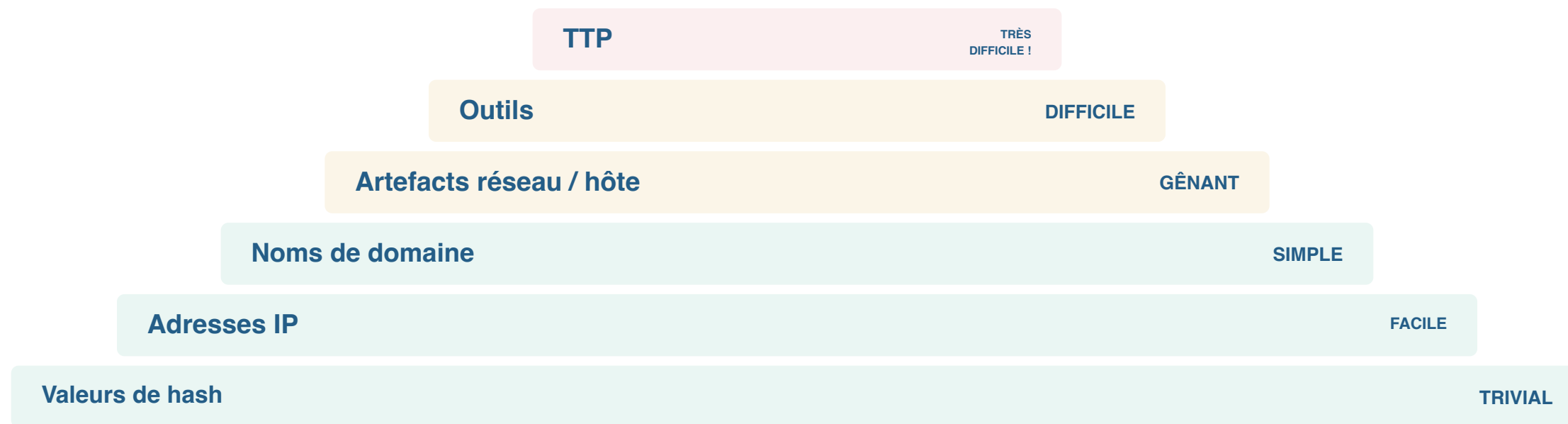
Chaque scénario est associé à une tactique et une technique. En voici un aperçu.

TACTIQUE	TECHNIQUE	ID
Accès initial	Phishing	T1566
Accès aux identifiants	Brute Force	T1110
Exécution	Interpréteur de commandes et scripts	T1059
Persistance	Tâche planifiée / démarrage automatique	T1053 / T1547
Mouvement latéral	SMB / partages administratifs Windows	T1021.002
Commandement et contrôle	Protocole de couche applicative	T1071
Impact	Chiffrement de données pour impact	T1486

La pyramide de la douleur

David J. Bianco

Quel coût imposez-vous à l'attaquant en détectant et bloquant chaque indicateur ? Plus on monte, plus le changement lui est difficile.



Qu'est-ce que cela change pour vous ?



En bas : rapide, mais fragile

Les correspondances IP et hash sont des pistes utiles. Vérifier ancienneté, source, contexte et autorisation avant de bloquer.



En haut : durable, mais exigeant

Les règles comportementales résistent parfois aux changements d'outils, mais exigent télémétrie, réglages et corroboration.

Le réflexe à acquérir : en créant ou ajustant une détection, demander « à quel niveau de la pyramide agit-elle ? ». Les détections comportementales vieillissent mieux que les listes d'indicateurs.

Un malware est un logiciel conçu pour nuire. Sa catégorie aide à anticiper la suite.

Trois axes de classification ; la plupart des échantillons réels les combinent.

Mode de propagation

Autoréplication, action utilisateur ou déploiement direct par un opérateur.

Fonction

Voler, espionner, chiffrer, détruire, miner ou donner le contrôle distant.

Dissimulation

Sur disque, surtout en mémoire (fileless) ou par rootkit ; des traces peuvent subsister.

Guide pratique — partie 1

1 / 2

Virus

S'attache à un fichier ou programme ; se propage à l'exécution du code infecté.

Ver

Se réplique sur le réseau sans action utilisateur et se propage vite.

Cheval de Troie

Se présente comme légitime pour pousser l'utilisateur à l'exécuter.

Ransomware

Chiffre ou verrouille les données pour extorquer ; un vol peut s'y ajouter. L'impact varie.

RAT

Remote Access Trojan : donne à l'opérateur un shell distant sur l'hôte.

Rootkit

Se dissimule au cœur de l'OS pour échapper aux utilisateurs et à de nombreux outils.

Guide pratique — partie 2

2 / 2

Spyware / Keylogger

Enregistre discrètement activité et frappes pour voler identifiants et données.

Agent de botnet

Intègre l'hôte à un réseau de bots commandés à grande échelle.

Dropper / Loader

Le dropper déploie une charge ; le loader charge ou récupère du code. Les rôles peuvent se recouper.

Fileless

Exécution surtout en mémoire ou détournement d'outils fiables ; des traces disque ou registre restent possibles.

Wiper

Détruit les données sans rançon, parfois sous l'apparence d'un ransomware.

Cryptomineur

Détourne discrètement le calcul pour miner des cryptomonnaies ; parfois premier signe d'intrusion.

De « qu'est-ce que c'est ? » à « que fait-il ? »

L'analyse transforme un fichier suspect en réponses exploitables et remplace les suppositions par une investigation précise.

Confirmer

Malveillant ou bénin ? Répondre avec des preuves.

Extraire les IOC

Hash, domaines, IP, mutex :
délimiter avec contexte ; partager
ou bloquer seulement après accord.

Comprendre l'impact

Vol, dégâts, persistance : préciser
le périmètre de l'incident.

Améliorer la détection

Écrire des règles pour la prochaine
fois, haut dans la pyramide de la
douleur.

Analyse statique

examiner sans exécuter

Inspecter sans exécution volontaire. Le packing peut masquer le contenu ; utiliser des outils à jour dans un environnement d'analyse approuvé.

Éléments à examiner

- Hash du fichier (MD5 / SHA-256)
- Chaînes : URL, IP, commandes
- Type de fichier et en-têtes PE
- API / fonctions importées
- Packing et entropie
- Correspondances de règles YARA

Les outils de l'équipe



PE-bear

Explore les en-têtes PE et les imports en profondeur.



FLOSS

Révèle les chaînes cachées par le malware pour extraire des IOC.

YARA

Les motifs repèrent des correspondances, sans garantir famille ou intention malveillante.



VirusTotal

Avis de plusieurs moteurs, pas un vote prouvant l'innocuité. Privilégier les recherches de hash approuvées.

Atout : triage rapide sans exécution volontaire.

Limite : packing et chiffrement masquent chaînes et code.

Analyse dynamique

exécuter et observer

Examiner le comportement dans une sandbox isolée approuvée. Entrées, environnement et évacion influent sur le résultat ; le silence ne conclut rien.

Éléments à observer

- Arbre des processus et enfants
- Modifications de fichiers et registre
- Trafic réseau / rappels C2
- Mécanismes de persistance créés
- Charges déposées ou téléchargées

L'outil d'orchestration



Cuckoo Sandbox

Enregistre le comportement dans une sandbox configurée.
Vérifier isolation et télémétrie ; aucun outil ne garantit la sécurité.

L1 lit les rapports fournis. Les labs réels distincts exigent sorties contrôlées, aucun dossier partagé ni véritable identifiant ; tout envoi exige un accord.

Atout : révèle comportement, C2 et persistance.

Limite : un malware détectant la VM peut rester inactif ; isoler.

Statique et dynamique : les combiner

	STATIQUE	DYNAMIQUE
Exécute le fichier ?	Non, examen au repos	Oui, exécution contrôlée
Vitesse	Rapide	Plus lente
Risque	Faible	Isolation nécessaire
Révèle	Structure, chaînes, IOC	Comportement, C2, persistance
Limites	Packing et obfuscation	Évasion de sandbox
Usage L1 typique	Triage par hash et chaînes	Lecture du rapport de sandbox

Les preuves statiques et dynamiques se complètent. Un rapport ne décrit qu'une exécution : corroborer actions et résultats avant de conclure.

Application au poste d'analyse



Trier, pas rétroconcevoir

Utiliser les recherches de hash approuvées et les rapports fournis. Préserver les preuves, expliciter l'incertitude et escalader l'analyse approfondie.



Alimenter la boucle

IOC → enrichissement Cortex / VirusTotal, MISP, OpenCTI. Comportements → nouvelles détections, haut dans la pyramide.



La sécurité avant tout

Aucun échantillon sur poste de travail ou en production. Analyse isolée approuvée ; aucun envoi public de fichiers, URL ou secrets sans autorisation.

Toute investigation répond à six questions

Que s'est-il passé ?

Quand : quelle chronologie ?

Où : quels hôtes ou composants ?

Qui / quel compte ?

Comment ont-ils procédé ?

L'activité continue-t-elle ?

...et les réponses alimentent une boucle reproductible :



Suite : neuf scénarios d’investigation

Ces scénarios encadrés ne sont pas neuf labs déployés dans le navigateur. L’application fournit des preuves synthétiques ; les outils réels sont distincts.

01	Force brute SSH	T1110	02	Phishing avec pièce jointe	T1566
03	Injection web (DVWA)	T1190	04	Mécanismes de persistance	T1547 / T1053
05	Mouvement latéral (SMB / PsExec)	T1021	06	Beaconing C2	T1071
07	Extraction d’identifiants	T1003	08	Commandes internes suspectes	T1059
09	Ransomware — cas de synthèse	T1486			

Des questions avant de passer à la pratique ?

Détecter, enquêter, répondre : une alerte à la fois. Vous avez les modèles de raisonnement ; place à leur mise en œuvre.

Kill Chain — où en est-on ? **ATT&CK** — quel comportement ? **Pyramide** — détecter plus haut.

Force brute SSH → Réussite

Attaque classique d'un service exposé : essayer des mots de passe SSH jusqu'au succès. Repérer les essais, puis le moment où ils aboutissent.

MITRE T1110 Brute Force

Tactique : accès aux identifiants

Kill Chain : selon les preuves

Cible : Linux · SSH :22

Qu'est-ce que SSH ?

Secure Shell · TCP :22

SSH offre à l'administrateur une ligne de commande distante chiffrée, remplaçant Telnet. Sa puissance explique aussi l'intérêt des attaquants.



Deux modes de connexion

Mot de passe : devinable ; limiter le débit et renforcer les contrôles.

Clé SSH : résiste aux essais ; protéger clés et phrases secrètes.

Pourquoi le cibler ?

Souvent exposé à Internet, SSH peut donner un shell complet. Des bots essaient les mots de passe à grande échelle.

Qu'est-ce qu'une attaque par force brute ?

T1110

Essayer sans cesse des identifiants jusqu'au succès, à vitesse automatisée. Un bot peut tester des milliers de mots de passe par minute sur un SSH exposé.

Essais de mots de passe .001

Tester un dictionnaire (ex. rockyou.txt) sur un compte.

Password spraying .003

Un mot de passe sur de nombreux comptes ; peut contourner certaines limites par compte, pas tous les contrôles.

Credential stuffing .004

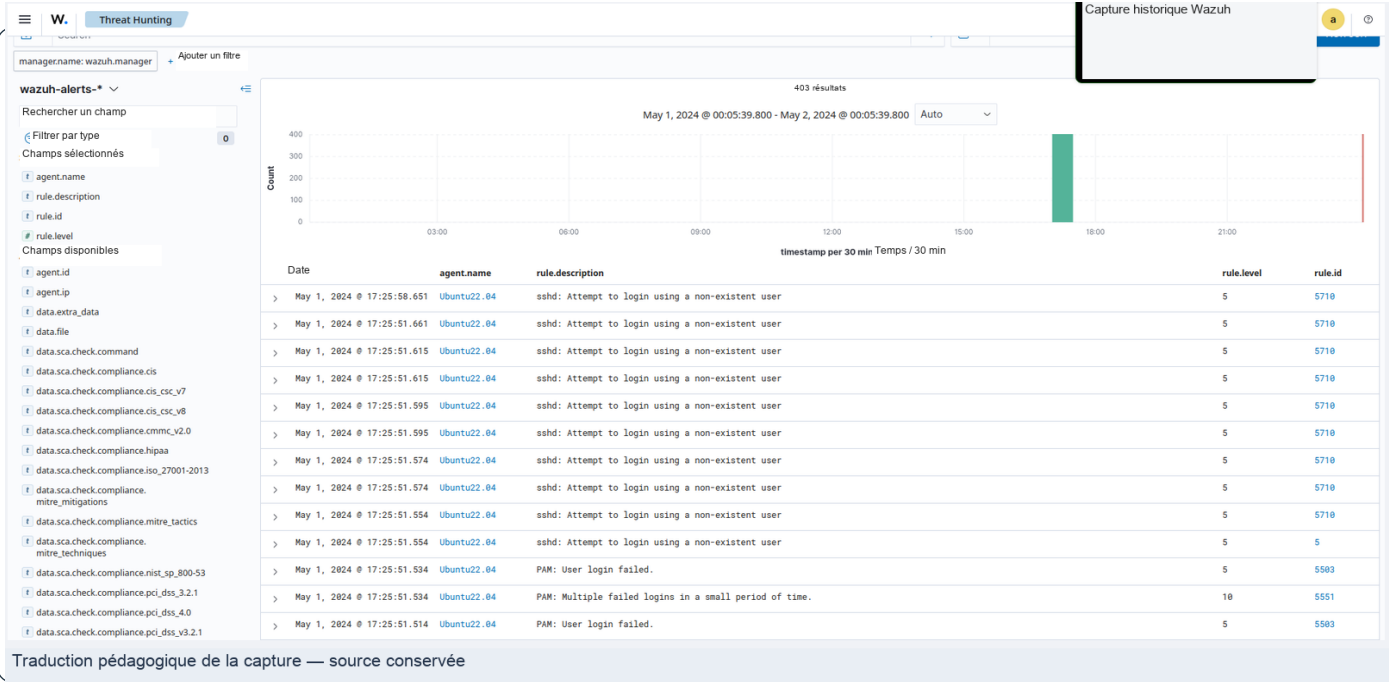
Réutiliser des couples identifiant-mot de passe issus d'autres fuites.

Reconnaître un succès

Échecs puis succès : corréler hôte, compte, source, méthode et session. Le succès ne prouve pas un accès non autorisé.

Indice : volume et rythme. Un humain n'échoue pas 400 fois par minute ; des bots ou scripts le peuvent.

Dans Wazuh, à quoi cela ressemble



Wazuh · Threat Hunting · wazuh-alerts-* — 403 résultats, agent Ubuntu22.04

la file d’alertes pendant l’attaque

Lire les alertes

Les 403 résultats montrent un volume d’alertes. Examiner les événements et leurs liens avant de qualifier l’activité.

- 5710

Tentative — utilisateur inexistant

L5
- 5503

PAM : échec de connexion utilisateur

L5
- 5551

PAM : échecs de connexion multiples

L10

Un succès 5715 exige une corrélation, pas un verdict automatique. Relier compte, hôte, source, heure et activité ultérieure.

Lab encadré distinct : cas SSH

L'exercice navigateur utilise des preuves fournies. La génération réelle exige des VM isolées approuvées, comptes fictifs et collecte vérifiée.

L'attaquant · Kali

Lance un outil d'essais de mots de passe contre la cible SSH du lab. Un identifiant valide a été prévu pour permettre un succès.

```
$ hydra -l student \  
-P wordlist.txt \  
ssh://<lab-target>
```

Vous · l'analyste

- Examiner les alertes Wazuh configurées
- Corréler source, compte, hôte et heure
- Lire auth.log / journal et logs de session
- Vérifier accès réussi et usage ultérieur
- Demander une réponse autorisée ; en vérifier l'effet

Prérequis : périmètre écrit, limites de débit, snapshots et nettoyage. Aucune cible de production ou publique, aucun vrai identifiant.

Phishing avec pièce jointe

Voie d'entrée fréquente : un message trompeur. Un utilisateur signale une pièce jointe suspecte ; la préserver et évaluer les preuves.

MITRE T1566.001

Spearphishing par pièce jointe

Tactique : accès initial

Cible : boîte de réception

Qu'est-ce que le phishing ?

la tromperie exploite la confiance

Un courriel trompeur pousse à ouvrir une pièce jointe ou un lien, donnant accès à du code ou à des identifiants. La confiance peut suffire, sans exploit logiciel.

Phishing de masse

Envoi à des milliers de personnes : peu d'effort, faible taux de réussite.

Spear phishing

Message ciblé sur une personne ou équipe, avec un contexte crédible.

Whaling

Vise les dirigeants : accès étendus et gains élevés.

Pièce jointe

Peut exécuter du code à l'ouverture si les protections ou les actions utilisateur le permettent.

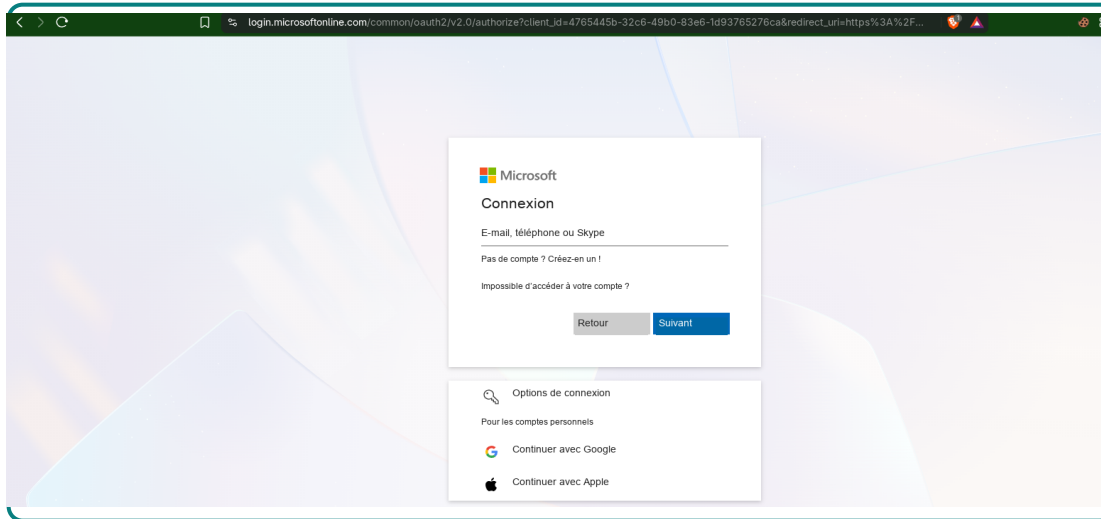
Lien

Mène à une fausse connexion pour voler les identifiants.

Votre grille de lecture : SPF / DKIM / DMARC

Authentifie des relations de domaines, pas l'innocuité du message ; un domaine ressemblant peut réussir les trois.

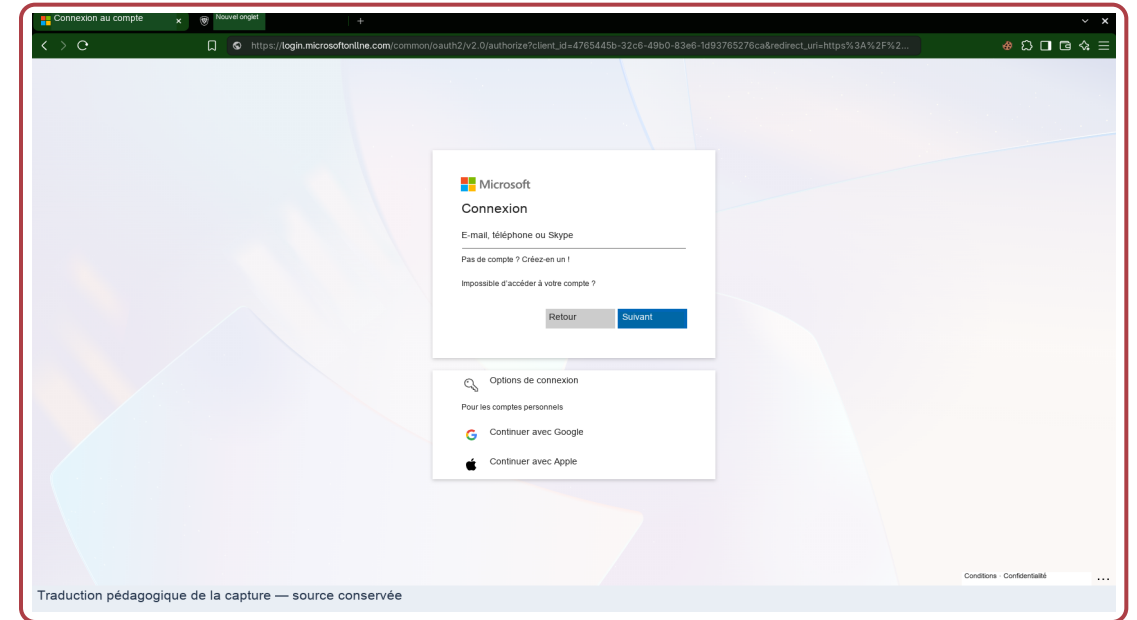
Repérer le domaine ressemblant



✓ login.microsoftonline[.]com

LÉGITIME — le véritable domaine Microsoft

même page — une lettre manque



⚠ login.microsoftonlne[.]com

MALVEILLANT — le « i » manque

Comparer le domaine réel, pas l'apparence. SPF / DKIM / DMARC peuvent valider un domaine de l'attaquant ; vérifier par un canal de confiance.

Comment la pièce jointe s'active

chaque étape laisse une trace →

1

Réception et ouverture du document

Document à macros ou raccourci déguisé.

en-têtes du courriel

2

Office lance un shell

WINWORD.EXE → powershell.exe : filiation révélatrice.

Sysmon 1 · 4104

3

Dépôt et exécution de la charge

Écrit un fichier temporaire ou de démarrage et l'exécute.

Sysmon 11

4

Rappels vers le C2

Le point d'appui demande des instructions.

Sysmon 3 · 22

EICAR teste uniquement l'antivirus : aucun shell ni C2. Utiliser les logs fournis ou un exercice à marqueurs validé dans un lab isolé distinct.

Enquêter sur le phishing

trier → évaluer → délimiter

COURRIEL

Analyse des en-têtes

Résultats SPF / DKIM / DMARC, Reply-To incohérent, domaine ressemblant.

PIÈCE JOINTE

Hash et lecture du rapport

Recherche de hash approuvée ; rapport de sandbox fourni. Aucun envoi public de fichier ou URL sans accord.

Sysmon 1

Office lance un shell

Indice majeur : WINWORD → powershell / cmd.

Sysmon 11 · 4104

Dépôt et bloc de script

Charge écrite sur disque ; logs des blocs PowerShell.

Préserver le message ; distinguer destinataires et exécution. Demander une réponse mail autorisée ; partager les indicateurs selon la politique.

Faux positifs possibles : marketing légitime, tests internes et sensibilisation. Vérifier avant d'alerter l'organisation.

Injection dans une application web sur DVWA

Attaques d'une application exposée et capacité à distinguer un scanner bruyant d'une intrusion réelle et ciblée.

MITRE T1190

Exploitation d'une application exposée

Tactique : accès initial

Cible : application web · DVWA

La cible : DVWA

Damn Vulnerable Web Application

Application PHP / MySQL volontairement vulnérable pour pratiquer et détecter des attaques web courantes dans un lab légal et contrôlé.

Pourquoi l'utiliser ?

- Vraies vulnérabilités, environnement isolé
- Difficulté réglable : low → impossible
- SQLi, XSS, injection de commandes, téléversement...
- Produit les logs web à analyser

Règle d'or : DVWA est volontairement vulnérable. Uniquement sur un réseau de lab isolé, jamais sur Internet.



Accueil

Instructions

Installer / réinitialiser la base

Force brute

Injection de commandes

CSRF

Inclusion de fichiers

Téléversement de fichiers

CAPTCHA non sécurisé

Injection SQL

Injection SQL aveugle

Identifiants de session faibles

XSS (DOM)

XSS réfléchi

XSS stocké

Contournement CSP

JavaScript

Sécurité DVWA

Informations PHP

Bienvenue dans Damn Vulnerable Web Application !

Damn Vulnerable Web Application (DVWA) est une application PHP/MySQL volontairement vulnérable. Elle permet aux professionnels de tester leurs compétences et outils légalement, aide les développeurs à comprendre la sécurisation des applications web et les enseignants à former dans un environnement contrôlé.

DVWA propose de pratiquer les vulnérabilités web les plus courantes à différents niveaux de difficulté, dans une interface simple.

Instructions générales

Vous pouvez parcourir tous les modules à un niveau donné, ou approfondir un module jusqu'au niveau le plus élevé avant de passer au suivant. Il n'existe pas d'objectif fixe de validation : cherchez à exploiter et comprendre la vulnérabilité avec vos connaissances actuelles.

Le logiciel contient volontairement des vulnérabilités documentées et non documentées. Essayez d'en découvrir autant que possible, uniquement dans le périmètre autorisé.

Cette capture historique décrit aussi PHPIDS comme protection supplémentaire activable pour augmenter la difficulté et montrer l'effet d'une couche de sécurité. Elle mentionne des méthodes de contournement pour les utilisateurs avancés. Vérifiez les fonctions de votre version : le réglage de difficulté n'installe pas un WAF.

Un bouton d'aide en bas de chaque page fournit des indices. Des liens complémentaires permettent d'approfondir le problème de sécurité étudié.

AVERTISSEMENT !

DVWA est vulnérable : ne jamais le déployer sur un hébergement public.

Traduction pédagogique de la capture — source conservée

Accueil DVWA : chaque menu propose une vulnérabilité à étudier

Qu'est-ce qu'une injection ?

quand l'entrée utilisateur devient du code

Une injection SQL modifie la structure d'une requête via une entrée non fiable. Les requêtes paramétrées séparent données et SQL ; le nettoyage seul ne suffit pas.

Connexion normale

Entrée : alice / s3cret

```
SELECT * FROM users
WHERE name='alice'
AND pass='s3cret';
```

→ une ligne correspond si le mot de passe est correct.

Connexion injectée

Entrée : ' OR '1'='1

```
SELECT * FROM users
WHERE name='alice'
AND pass=" OR '1'='1';
```

→ vrai ici ; l'application décide de l'authentification.

Syntaxe SQL ou indices de scanner dans les logs : ni les motifs de requêtes ni les statuts HTTP ne prouvent seuls l'exploitation ou l'intention.

Persistence survivre au redémarrage

L'attaquant cherche à conserver son accès après un redémarrage. Repérer les mécanismes qui rétablissent son point d'appui.

MITRE T1547.001 / T1053.005

Clés Run · tâches planifiées

Tactique : persistance

Plateformes : Windows et Linux

Qu'est-ce que la persistance ?

retrouver automatiquement un accès

La persistance maintient l'accès malgré les interruptions. Les démarrages automatiques relancent du code ; comptes et clés SSH permettent un accès ultérieur sans exécution automatique.



Sur Windows

Clés Run du registre, tâches planifiées, services et dossier de démarrage.

Sur Linux

cron, compte dérobé dans /etc/passwd, authorized_keys, unités systemd.

Où se cachent-ils ?

six emplacements, chacun avec ses traces →

Clé Run du registre T1547.001 Exécution à l'ouverture de session. Sysmon 13 · 4657	Tâche planifiée T1053.005 schtasks /create 4698 · Sysmon 1	Nouveau service T1543.003 Démarrage possible au boot ; compte configurable. 7045
Tâche cron T1053.003 Exécution planifiée Linux. auditd · FIM 550	Compte /etc/passwd T1136.001 Nouveau compte ; UID 0 est un cas à risque. FIM 550	authorized_keys T1098.004 Ajout de la clé SSH de l'attaquant. FIM 550 / 554

La télémétrie configurée révèle créations et changements. L'enregistrement ne prouve pas l'exécution : vérifier action, propriétaire et résultat.

Détecter l'installation

qui l'a créée, et quand ?

Windows 4698

Création d'une tâche planifiée

4657 / Sysmon 13 pour l'écriture d'une clé Run.

Sysmon 1

La commande responsable

schtasks, reg add, sc create — et le parent.

Wazuh FIM 550 / 554

Surveillance des fichiers Linux

Création / modification de /etc/passwd ou authorized_keys.

auditd

Qui et quand

Utilisateur, session et horodatage du changement.

Enquête : relier créateur, session et éventuelle connexion suspecte précédente. **Reconstituer :** connexion → persistance → exécution.

Faux positifs : installateurs (OneDrive, Teams), mises à jour et créations de comptes par l'IT. Documenter une référence légitime.

Mouvement latéral

PsExec et Impacket

Un point d'appui peut servir à atteindre d'autres systèmes. Suivre les accès entre hôtes étayés par les preuves, sans présumer la compromission du domaine.

MITRE T1021.002

SMB / partages administratifs Windows

Tactique : mouvement latéral

Cible : Windows · Active Directory

Qu'est-ce que le mouvement latéral ?

d'un point d'appui vers d'autres hôtes

Depuis une machine, l'attaquant utilise des identifiants valides pour atteindre serveurs, partages et contrôleur de domaine. Il peut simplement se connecter, sans nouvel exploit.



Sur Windows

Partages SMB + PsExec / Impacket, WMI, WinRM, RDP avec mots de passe ou hash volés (pass-the-hash).

Sur Linux

SSH et clés volées, détournement d'agent SSH, outils de configuration (Ansible, Salt) : même tactique, autres mécanismes.

Fonctionnement de PsExec / Impacket

chaque étape laisse une trace →

Lab isolé uniquement : psexec.py CORP/admin:'....'@10.0.0.5 cmd.exe

1

Authentification SMB

Connexion TCP 445 avec identifiants administrateur ou hash volé.

4624 Type 3 · 4672

2

Dépôt d'un binaire sur ADMIN\$

Copie d'un exécutable de service dans un partage accessible ; chemin et nom varient.

5140 / 5145 ADMIN\$

3

Création et démarrage d'un service

Enregistrement du binaire via le tube SVCCTL sur IPC\$.

7045 : service installé

4

Exécution SYSTEM et relais des E/S

Le service exécute les commandes ; un tube nommé transporte les entrées/sorties.

tube \RemCom_*

Le repérer dans les logs

Wazuh collecte ces événements Windows et Sysmon

7045 · System

Service installé

Vérifier chemin de l'exécutable, compte et créateur.

4624 + 4672

Connexion réseau

Type 3 avec privilèges administrateur depuis un hôte inhabituel.

5140 / 5145

Accès au partage

Accès / droits demandés ; corroborer les écritures réelles.

Sysmon 1

Arbre de processus inhabituel

Le binaire de service lance cmd.exe / powershell.

Sysmon 3

Port 445 interne

Connexions SMB entre hôtes communiquant rarement.

Sysmon 17 / 18

Tube nommé

\RemCom_* (Impacket) ou \PSEXESVC.

Indice : installation 7045 juste après un 4624 Type 3 provenant d'un hôte qui n'administre pas cette cible. Puis pivoter : compte, source, destination et nombre d'hôtes.

Faux positifs : SCCM, assistance distante et agents de sauvegarde. Distinguer par compte, horaires et couples d'hôtes.

Beaconing C2 le battement régulier

Certains C2 utilisent des rappels récurrents. Corréler rythme, destination et processus ; tous les malwares ne font pas de beaconing.

MITRE T1071

Protocole de couche applicative

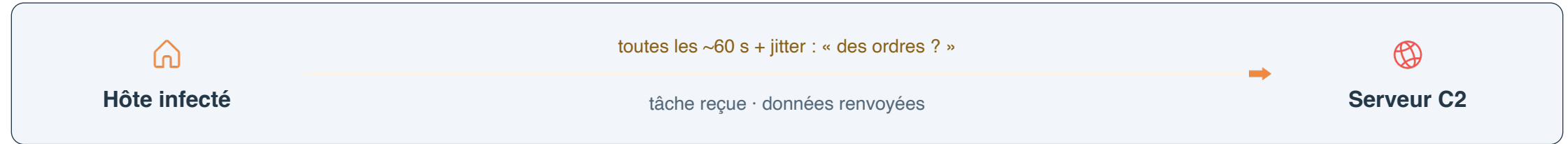
Tactique : commandement et contrôle

Canaux : HTTP(S) · DNS

Qu'est-ce que le beaconing C2 ?

contacter le serveur à intervalles réguliers

Après implantation, le malware contacte périodiquement son serveur de commandement et contrôle pour obtenir des tâches, rendre compte ou exfiltrer. Ce rappel est le beacon.



Canaux

HTTP/HTTPS se fond dans le web ; le tunneling DNS dissimule les données dans les requêtes.

Frameworks de lab

Privilégier les traces synthétiques ou marqueurs validés. Les frameworks C2 exigent périmètre explicite et isolation.

Les indices du beacon

ce qui distingue son rythme

La régularité est une piste, pas un verdict. Un malware peut être irrégulier ; un agent légitime peut être périodique.

Intervalle régulier et jitter

Connexions toutes les ~N secondes avec légère variation aléatoire : un rythme, pas une navigation.

Taille identique des requêtes

Même longueur d'URI et même volume d'octets, répétés.

User-agent / JA3 inhabituel

UA rare ou empreinte TLS JA3 associée à un outil connu.

DNS inhabituel

Noms longs à forte entropie et volume élevé : tunneling possible, à corroborer.

Attention : mises à jour, NTP et télémétrie sont aussi périodiques. Détecter le beaconing exige régularité et contexte suspect, jamais la régularité seule.

Rechercher le canal

détecter → enrichir → élargir

Sysmon 3 · 22

Vue endpoint

Connexions répétées vers une destination ; volume et entropie DNS.

Suricata / Zeek

Vue réseau

Signatures Suricata ; métadonnées Zeek. Les empreintes TLS exigent une configuration compatible.

MISP / OpenCTI

Enrichir la destination

Vérifier source, ancienneté et confiance. IP / ASN partagés ne prouvent pas un acteur commun.

Tableau de bord

Élargir la recherche

Quels autres hôtes contactent périodiquement cette destination ?

Motif → corroboration hôte et réseau → périmètre des activités liées. Une correspondance de renseignement ne prouve ni compromission ni attribution.

Mises à jour et télémétrie sont fréquentes. Escalader le risque urgent pour un confinement autorisé, sans attendre une réputation malveillante connue.

Extraction d'identifiants LSASS et Mimikatz

Les attaquants peuvent chercher des secrets dans LSASS. Leur disponibilité et les protections varient ; l'accès administrateur ne garantit pas le succès.

MITRE T1003.001

Extraction d'identifiants OS : mémoire LSASS

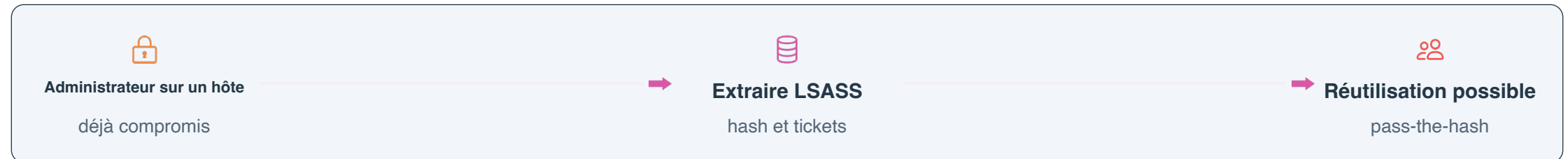
Tactique : accès aux identifiants

Accès privilégié ; blocage possible

Qu'est-ce que l'extraction d'identifiants ?

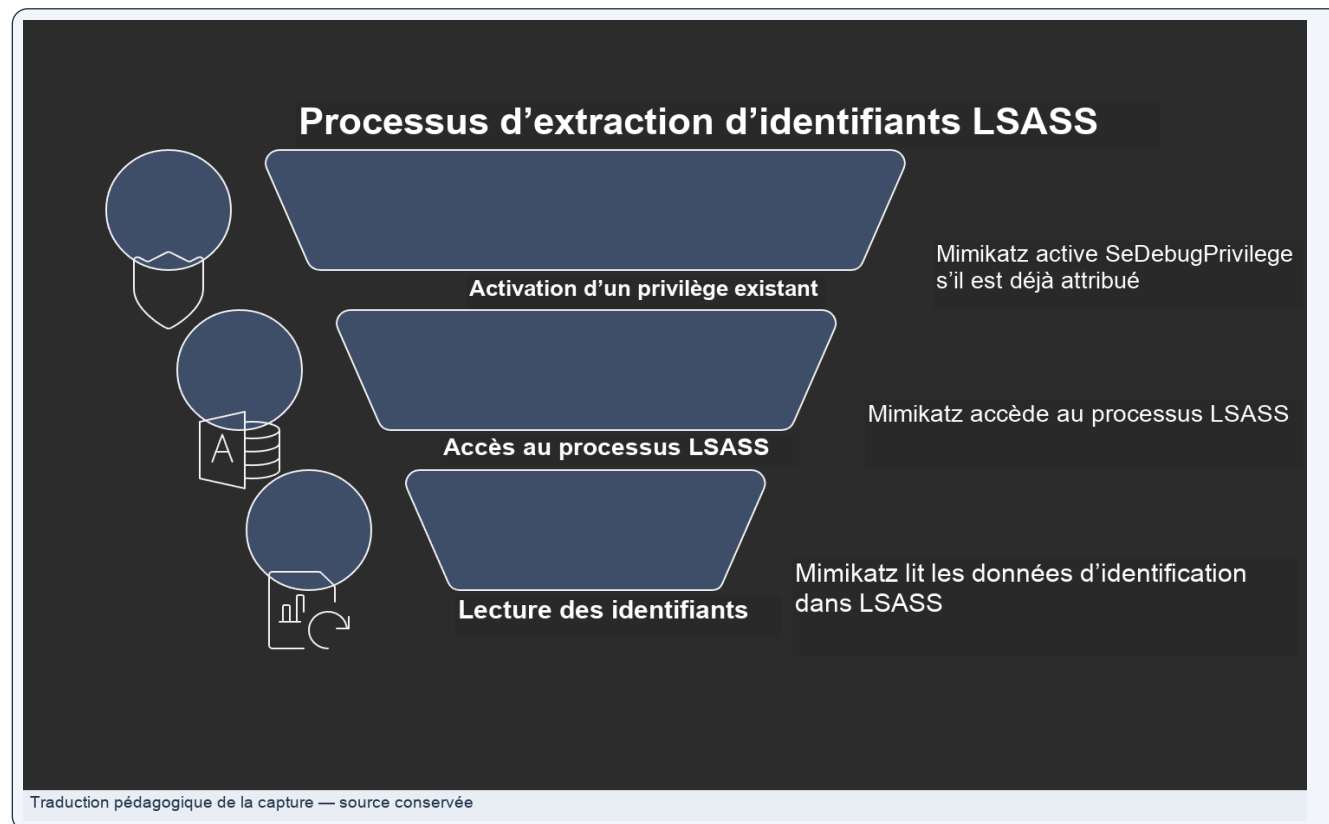
voler les clés, éviter les serrures

LSASS gère l'authentification Windows. Sa mémoire peut contenir hash ou tickets ; le texte clair dépend de la configuration. Extraction et réutilisation dépendent des protections, sessions et droits.



Dans l'extraction mémoire

trois étapes, trois signaux



Ce que voit l'analyste

1 · Privilège de débogage existant

Un droit déjà attribué peut être activé ; cela ne prouve pas une élévation de privilèges.

2 · Accès à LSASS

Sysmon 10 peut enregistrer l'accès ; les masques varient et ne prouvent pas une extraction.

3 · Lecture des identifiants

Lecture mémoire ou création d'un dump. Corréler contenu et résultat ; aucun fichier disque n'est nécessaire.

Comment extraire LSASS

outils différents, indices similaires →

Exemple à reconnaître dans les logs : `rundll32 comsvcs.dll, MiniDump <lsass_pid> out.dmp full`

Mimikatz

Sysmon 10

sekurlsa::logonpasswords lit directement la mémoire LSASS.

comsvcs MiniDump

Sysmon 1 + 11

Une DLL Windows native (LOLBin) écrit LSASS dans un fichier .dmp.

ProcDump

Sysmon 1 + 11

Outil Microsoft signé — -ma lsass.exe — détourné pour extraire la mémoire.

Gestionnaire des tâches

Sysmon 11

Clic droit → « Créer un fichier de vidage » : aucun outil adverse nécessaire.

L'accès direct à LSASS peut laisser des traces d'accès processus ; l'évasion et les méthodes alternatives empêchent tout événement universel.

Living off the Land

LOLBins : les outils légitimes peuvent être détournés

Binaires, scripts et bibliothèques fiables peuvent être détournés. Certains sont natifs, d'autres installés. La signature ne garantit pas l'innocuité ; charges et traces peuvent atteindre le disque.

rundll32 + comsvcs

Extraire la mémoire LSASS : notre scénario.

certutil

Télécharger et décoder des charges web.

regsvr32

Exécuter des scripts distants (« Squiblydoo »).

mshta

Exécuter des HTA / scriptlets distants.

bitsadmin

Télécharger discrètement via des tâches BITS.

wmic

Exécution distante et reconnaissance système.

Les outils fiables se confondent avec l'administration. Restreindre les capacités inutiles selon la politique ; corrélérer comportement et autorisation.

Détection : comportement, pas nom du fichier. Filiation et arguments inhabituels (Sysmon 1, PowerShell 4104), en haut de la pyramide de la douleur.

Détecter l'extraction

surveiller qui accède à LSASS

Sysmon 10 · ProcessAccess

Un handle vers lsass.exe

Masques d'accès (ex. 0x1010 / 0x1410) : des pistes, pas des signatures uniques.

Sysmon 1 · Process

Commandes révélatrices

comsvcs.dll, MiniDump, procdump -ma, commandes mimikatz.

Sysmon 11 · FileCreate

Un dump écrit sur disque

Création de lsass.dmp / d'un .dmp dans un chemin temporaire.

Windows 4656 / 4663

Accès aux objets

Dépend de l'audit et des stratégies ; valider prise en charge et champs collectés.

Corréler processus source, cible, accès, commande et résultat. Ni un nom d'outil connu ni un accès isolé ne suffisent à établir l'intention.

Faux positifs : AV/EDR, ProcDump utilisé par l'IT, outils de diagnostic. Vérifier les usages légitimes de référence.

Menace interne et commandes suspectes

Un compte valide exécute des commandes suspectes. Droit technique et autorisation métier différent ; les logs seuls ne prouvent pas l'intention humaine.

MITRE T1059

Interpréteur de commandes et scripts

Tactique : exécution

Contexte : interne / compte volé

Quand la menace vient de l'intérieur

l'intention, pas les exploits

Un salarié malveillant ou un compte détourné abuse d'un accès normal : fouille, préparation de données, accès persistant. Un shell et des commandes ordinaires suffisent.

Indices possibles

- whoami, id, sudo -l : reconnaissance
- cat /etc/shadow : accès aux secrets
- tar -czf : archivage d'un dossier sensible
- scp vers un hôte externe : exfiltration possible

La fiche de contexte

Mêmes commandes, explications concurrentes :

Ticket de maintenance → vérifier le périmètre exact.

Utilisateur parti → enquêter sur l'usage du compte.

Le contexte éclaire ; les preuves tranchent.

Anatomie d'une session suspecte

auditd configuré enregistre certaines activités →

1

Reconnaissance

whoami · id · sudo -l · uname -a

auditd 80792

2

Sonder privilèges et secrets

tentatives sudo · cat /etc/shadow

règles sudo

3

Préparer un retour

echo key >> ~/.ssh/authorized_keys

FIM 550 / 554

4

Préparer et exfiltrer

tar -czf /tmp/staged.tar /var/www · scp → externe

auditd 80792

Rien de tout cela n'est un « malware ». La séquence reconnaissance → secrets → persistance → exfiltration donne son sens à l'activité.

Reconstituer et évaluer

le contexte est déterminant

Wazuh auditd 80792

Exécution de commandes

Événements execve configurés, utilisateur et heure ; pas toutes les actions du shell.

Abus de sudo

Sondage des privilèges

Échecs sudo, accès à /etc/shadow, actions root imprévues.

FIM 550 / 554

Modification de authorized_keys

Comparer contenu, propriétaire et autorisation du changement.

scp / trafic sortant

Où sont parties les données ?

Vérifier destination et résultat ; une commande seule ne prouve pas un vol.

Enquête : reconstruire la session, identifier les données consultées et préparées, suivre la destination scp et obtenir le contexte RH / managérial.

Relier accord, compte, commande, hôte et heure. Réserver les informations personnelles sensibles aux circuits autorisés.

Ransomware

Exercice de réponse sur table : croiser les preuves, prioriser les décisions et demander des actions autorisées. Le navigateur n'exécute ni ransomware ni restauration.

MITRE T1486 · T1490

Chiffrement de données pour impact

Tactique : impact

Kill Chain : actions sur les objectifs

Qu'est-ce qu'un ransomware ?

la phase finale visible

Chiffrement massif suivi d'une demande de rançon. Il intervient souvent après une intrusion en plusieurs étapes plutôt qu'au début.

Chiffrement

Fichiers verrouillés, extensions changées (.locked), note de rançon déposée.

Double extorsion

Données volées avant chiffrement : payer ou subir leur publication.

Wiper déguisé

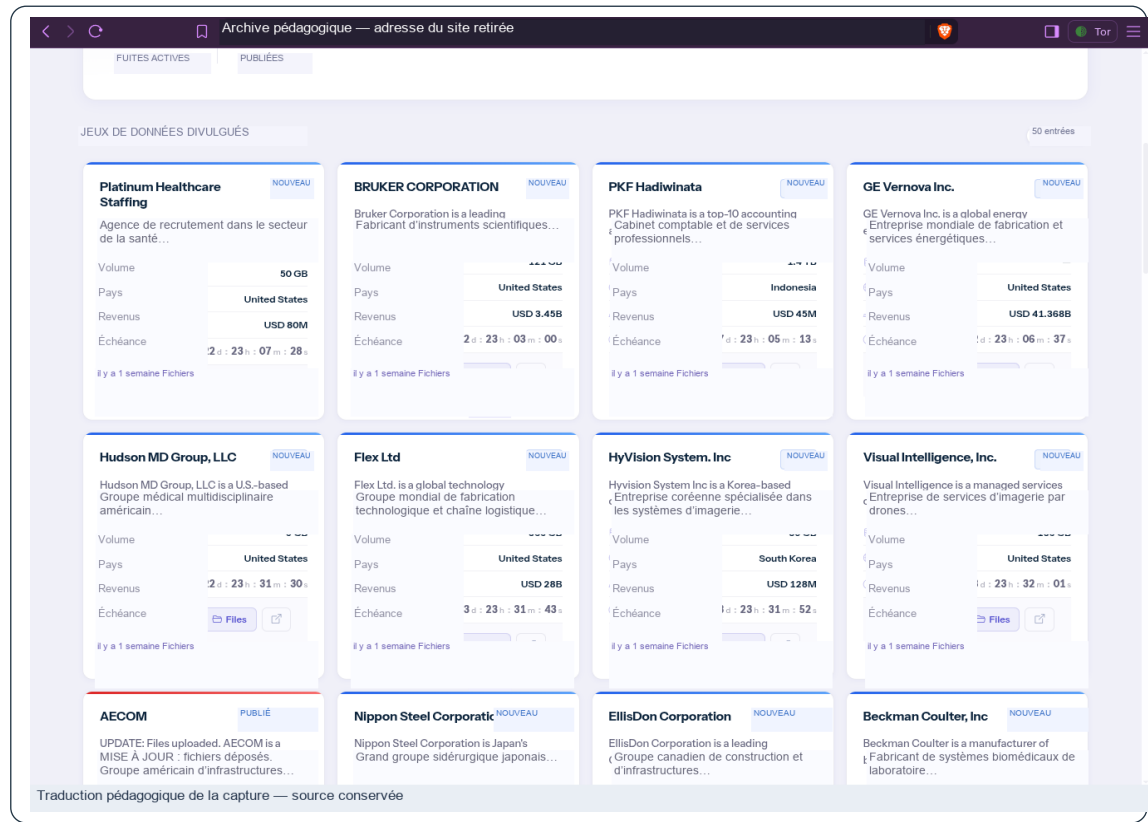
Certains « ransomwares » détruisent sans déchiffrer. Une note de rançon n'offre aucune garantie.



Rechercher accès antérieur, persistance, mouvement et vol lorsque les preuves les étayent. Tous les incidents ne comportent pas toutes les étapes.

Le site de publication des fuites

la double extorsion au grand jour



Site de fuite de ransomware (DLS) sur Tor : victimes et affirmations publiées par l'acteur

Ce que vous observez

- L'acteur revendique un vol ; vérifier par des preuves autorisées. Une sauvegarde n'annule pas une divulgation confirmée.
- Compte à rebours : « payez ou nous publions ». Une pression délibérée.
- Noms, volumes et « Files » sont des affirmations, pas des preuves indépendantes.
- Onglets NEW / PUBLISHED : chronologie publique de l'extorsion.
- Si votre organisation apparaît, escalader cette affirmation non vérifiée. Juristes et responsables d'incident évaluent preuves et obligations de notification.

Capture archivée uniquement : ne pas visiter le site ni récupérer les données volées.

Suivre l'argent

Affaire LockBit — accusations officielles de mai 2024

Dmitry Yuryevich Khoroshev



Dmitry Yuryevich Khoroshev identifié par la NCA, le FBI et leurs partenaires comme « LockBitSupp », administrateur de LockBit. Sanctionné en mai 2024.

500 M\$+

rançons alléguées

100 M\$+

gains allégués de l'administrateur

2 500+

victimes dans le monde

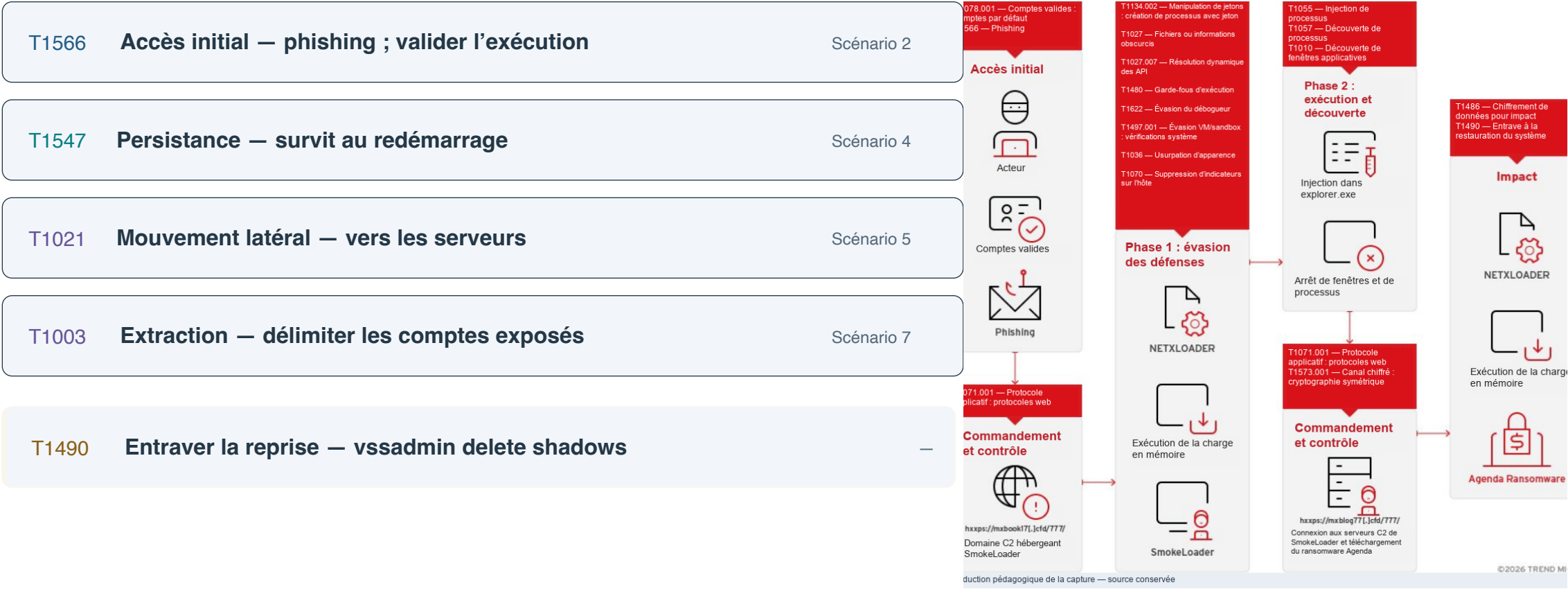
Jusqu'à 10 M\$

pour des informations admissibles (2024)

Le gain est l'objectif. Dans le modèle Ransomware-as-a-Service décrit, le noyau finance la R&D ; les affiliés mènent les attaques contre environ 80 % des revenus. Des intrusions longues et sophistiquées deviennent une activité lucrative.

Toute la chaîne dans un incident

les scénarios convergent ici

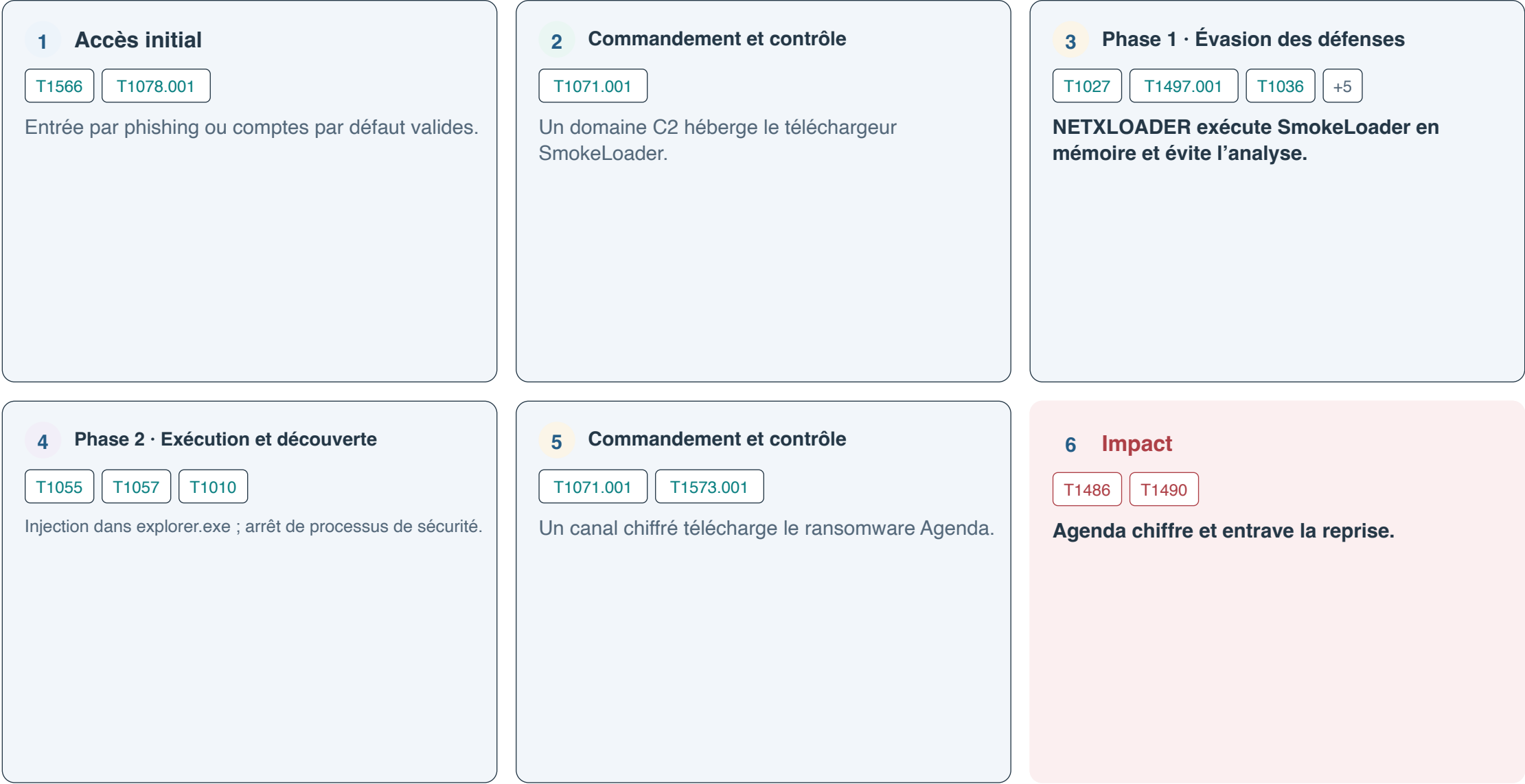


T1486 Chiffrer — impact fichiers ; prouver le vol séparément

IMPACT

Chaîne réelle : ransomware Agenda

Trend Micro · 7 mai 2025 · campagne rapportée, pas
séquence universelle



La déferlante d'alertes

quand tout se déclenche à la fois

Wazuh FIM 550 x milliers

La vague de chiffrement

Des changements massifs peuvent signaler un chiffrement ; vérifier aussi sauvegarde et maintenance.

Sysmon 1

Les commandes déclencheuses

Processus de chiffrement ; vssadmin delete shadows.

Sysmon 11

La note de rançon

Note de type README.txt écrite dans chaque dossier.

Active Response

Réagir rapidement

Seuls les scripts configurés et testés agissent ; accord et retour arrière sont nécessaires.

Prioriser les dommages en cours et services touchés ; escalader immédiatement. La recherche du premier accès ne doit pas retarder un confinement autorisé.

Parcourir toute la boucle

le travail de bout en bout

01

Détecter et trier

Évaluer l'impact, préserver les preuves, escalader au responsable.

02

Contenir

Les intervenants autorisés limitent l'accès ; vérifier effets et impact métier.

03

Éradiquer

Les responsables autorisés retirent la persistance et corrigent la voie d'entrée.

04

Rétablir

Les responsables valident une reprise saine et surveillent les récides.

05

Communiquer

Direction d'incident, dirigeants, juristes et communication : informer les parties prenantes.

06

Tirer les enseignements

Améliorer les contrôles, attribuer les actions et vérifier les corrections, sans promettre zéro récive.

L1 préserve les preuves, recommande et suit les actions. Distinguer demandé, approuvé, exécuté et vérifié ; communiquer tout au long de l'incident.

Des questions ?

Posez vos questions, nous sommes là pour vous aider.

Merci de votre participation. Pratiquez avec les preuves du navigateur ; demandez au formateur les modalités d'un éventuel lab distinct.

Détecter tôt · garder son calme · tout documenter

Merci

Architecture et ingénierie SOC

En séance : flux, rôles, collecte, règles, FIM, RBAC et reprise.
Wazuh est intégré au fil des sujets.

55 sources conservées · Terraform, Swarm, Ansible et CI : approfondissements.

Cires CYBER ACADEMY · CONSTRUIRE UN SOC

Formation SOC Architect

Ateliers d'infrastructure isolée avec formateur : OpenStack, Terraform, Swarm personnalisé, Ansible et GitLab CI

Support source · 6 modules · Parcours actuel : jour 3

La formation en un coup d'œil

01

**Architectur
e et cycle
de vie**

**Module
source**

02

**OpenStack
& Terraform**

**Module
source**

03

**Docker
Swarm**

**Module
source**

04

**Automatisat
ion avec
Ansible**

**Module
source**

05

**Exploitation
des
services**

**Module
source**

06

GitLab CI

**Module
source**



Programme source : six modules, non six jours. Parcours actuel : jour 3. Les ateliers nécessitent les ressources externes du formateur.

Environnement et prérequis



Accès OpenStack

Projet isolé autorisé, identifiants à droits limités, quotas, clouds.yaml et accès SSH vérifié.



Paire de clés SSH

Clé publique importée dans OpenStack. Clé privée sur votre poste.



Outils du poste de travail

Versions fixées par le formateur : outils, collections, OS, images, Wazuh et paquets signés.



Compte GitLab

Projet et runner de formation approuvés ; aucun accès à la production.

Quotas indicatifs — à valider

Nœud	Gabarit	Rôle
swarm-manager	4 vCPU · 8 Go	Héberge l'indexer
swarm-worker-1	2 vCPU · 4 Go	Manager, dashboard
swarm-worker-2	2 vCPU · 4 Go	Capacité disponible
Total	8 vCPU · 16 Go	+ 3 IP flottantes



ARRÊT sans les ressources externes ~/soc-lab validées ; elles ne sont pas fournies dans ce dépôt.

Wazuh : établir le contrat de laboratoire

01

Vérifier les prérequis

Le formateur fournit l'environnement hors production, les versions compatibles, les ressources revues et les accès. Le cours et l'application ne créent pas ces ressources et ne prouvent aucun déploiement.

02

Situer chaque composant

Agent : collecte sur l'hôte.
Manager : réception et analyse.
Indexer : indexation et recherche.
Dashboard : interface utilisant les données indexées et l'API de gestion.

03

Accepter sur des preuves

Documenter cible, créneau, responsable, versions, confiance et événement récent. Sans ressources validées, travailler sur dossier et annoncer explicitement cette limite.

01

Architecture et cycle de vie

Module source · Composants SOC, parcours des événements de bout en bout, responsabilités, topologie, dimensionnement, sauvegarde, mises à niveau et limites de résilience

Les composants de notre SOC



Agent Wazuh

Collecte les logs, le FIM et l'inventaire. Active Response uniquement si explicitement configuré et autorisé.



Manager Wazuh

Reçoit et décode les événements, évalue les règles et génère les alertes. Gère les agents et l'API.



Filebeat

Transmet les alertes et, en option, les archives du manager à l'indexer via TLS.



Indexer Wazuh

Stockage fondé sur OpenSearch. Indexe les alertes, permet leur recherche et gère leur conservation.



Dashboard Wazuh

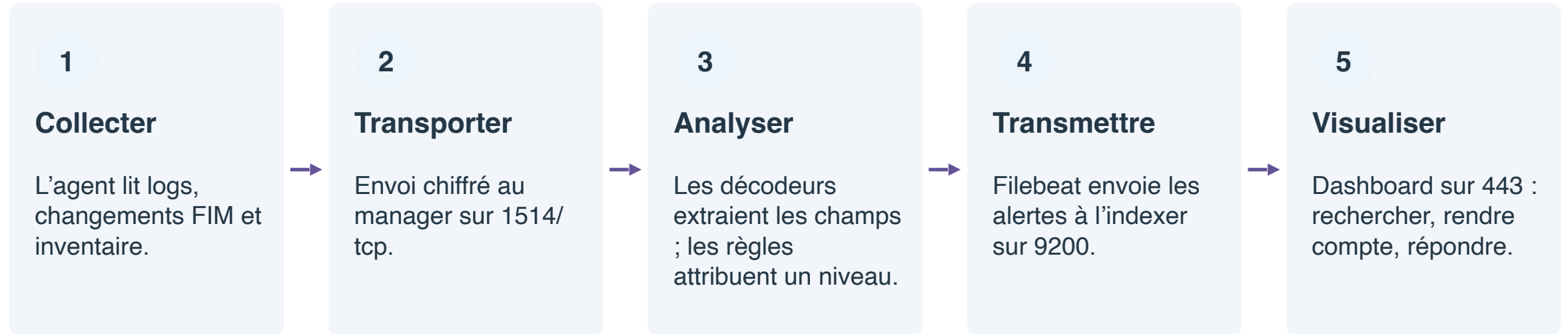
Interface web : événements, agents, FIM, vulnérabilités, MITRE et RBAC.



Transmission

Les intégrations transmettent des alertes sélectionnées ; une notification ne prouve ni confinement ni réponse.

D'une ligne de log à une alerte



Parcours indicatif ; vérifier les règles installées

Échec SSH autorisé → log source → décodeur/règle → alerte du manager → recherche indexée

Collecte : de la source au manager

01

La source doit produire

Confirmer que l'application écrit le journal ou que le canal Windows existe. Une politique de collecte correcte ne crée pas rétroactivement un événement jamais produit.

02

L'agent doit lire

Contrôler chemin ou canal, format, droits de lecture et configuration appliquée. Les chemins Linux dépendent de la distribution et de la journalisation réellement installée.

03

Le manager doit recevoir

Wazuh logcollector collecte, remoted reçoit les événements des agents et analyse les analyse. Localiser la première preuve manquante avant de changer une règle ou un seuil.

Alertes et archives : choisir la conservation

01

Deux ensembles différents

alerts.json contient les alertes produites selon la configuration. L'archivage des événements reçus est une option distincte ; activer la collecte ne signifie pas conserver chaque événement dans un index.

02

Dimensionner avant d'activer

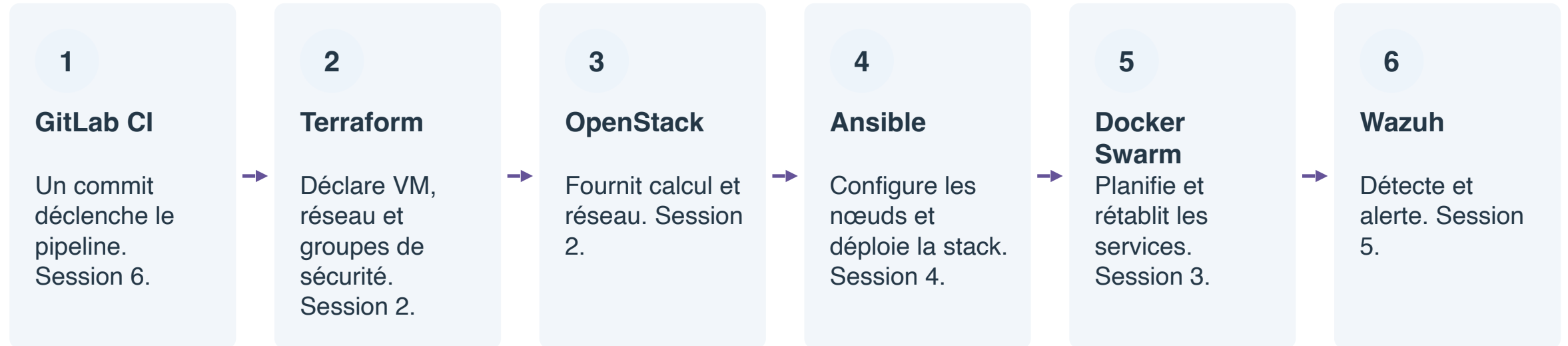
L'archivage intégral augmente stockage, charge et exposition des données. Définir catégories, accès, durée, suppression et gels de conservation avant tout changement.

03

Corriger la référence historique

Pour PCI DSS v4.0.1, exigence 10.5.1 : au moins 12 mois d'historique, dont 3 immédiatement disponibles. Cette exigence concerne le périmètre applicable, pas une durée universelle pour tous les journaux.

Comment les composants s'articulent



État : backend Terraform configuré, Raft Swarm, volumes Wazuh, secrets protégés. Git seul ne constitue pas une sauvegarde.

Flux réseau à autoriser

Port	Protocole	Source → Destination	Usage
22	TCP	Administration → tous les nœuds	SSH, Ansible
2377	TCP	Nœuds → managers Swarm	Gestion du cluster
7946	TCP/UDP	Nœud ↔ nœud	Gossip / découverte Swarm
4789	UDP	Nœud ↔ nœud	Réseau overlay (VXLAN)
1514	TCP	Agents → manager	Événements des agents
1515	TCP	Agents → manager	Enrôlement des agents
55000	TCP	Dashboard / administration → manager	API Wazuh
9200	TCP	Filebeat, dashboard → indexer	API de l'indexer
443	TCP	Analystes → dashboard	Interface web

API et dashboard : confiance avant accès

01

Valider l'identité du serveur

Contrôler URL approuvée, CA, SAN et dates pour le dashboard, l'API et les flux concernés. Un avertissement bloque l'exercice jusqu'à correction ; aucune désactivation de vérification TLS.

02

Protéger les secrets

Utiliser les identifiants d'atelier remis en privé et un mécanisme approuvé de gestion des jetons. Ne pas conserver de secret dans un support, une capture, un historique shell ou un dépôt.

03

Tester une lecture limitée

Vérifier une requête autorisée correspondant à la version fournie. Distinguer échec de confiance, refus d'authentification et refus d'autorisation avant de modifier une configuration.

Dimensionner la plateforme

Composant	Atelier du jour	Hypothèses indicatives
Manager	2 vCPU · 4 Go	4–8 vCPU · 8–16 Go, selon les agents et EPS
Indexer	4 vCPU · 8 Go	3 nœuds, 16–32 Go RAM chacun, SSD rapides
Dashboard	1 vCPU · 2 Go	2 vCPU · 4 Go
Stockage	50 Go	Croissance primaire mesurée × jours × copies × 1,2

Exemple chiffré

5 Go/jour × 90 jours × 2 copies

≈ 1,1 To

croissance indexée × copies × 1,2 (+20 %)

Facteurs : agents · EPS · conservation · réplicas

Sauvegardes, mises à niveau et limites



Sauvegarde

Manager : /var/ossec/etc, règles et décodeurs personnalisés, client.keys, groupes d'agents.

Indexer : snapshots.

Certificats et secrets.

Protéger aussi l'état Terraform et les métadonnées de reprise.



Mises à niveau

Ordre : indexer → manager → dashboard → agents.

Agents jamais plus récents que le manager.

Canari, restauration testée et guide adapté aux versions.



Limites de résilience

Manager arrêté : tampons limités ; retard/perte possibles.

Indexer arrêté : file d'envoi ; recherche indisponible/périmée.

Quorum Swarm perdu : services actifs, modifications bloquées.

Nœud perdu : tâches sans état déplacées, tâches contraintes en attente.

Reprise et exploitation : conserver la confiance

01

Sauvegarder les dépendances

Préserver base du manager, identités d'agents, configurations, snapshots compatibles, état du dashboard, certificats, secrets et métadonnées d'infrastructure selon la procédure approuvée.

02

Restaurer sans collision

Répéter la reprise dans un environnement isolé compatible, sans identité clonée contactant des agents réels. Reconstruire des VM vides ou revenir à une image ne restaure pas automatiquement les données.

03

Revalider le service

Exiger recherche historique et canari récent sous le compte lecteur prévu. Consigner point et durée de reprise, intervalles perdus, capacité restante et limites avant décision de remise en service.

Vérification des acquis

Objectif

Partager une même compréhension de l'architecture avant de commencer la construction.

1. Ouvrez le lien du formulaire partagé dans le chat.
2. Répondez à 10–15 questions : QCM et courts scénarios.
3. Envoyez vos réponses, puis examinez les résultats ensemble.
4. Reprenez les sujets moins maîtrisés avant la session 2.

Exemples de questions

- Quel port un agent utilise-t-il pour s'enrôler ?
- Quel composant évalue les règles ?
- Indexer arrêté : que deviennent les nouvelles alertes ?
- Que contient l'état Terraform ?

02

Provisionnement OpenStack et Terraform

Module source · Projets, réseaux, groupes de sécurité et gabarits OpenStack · Providers, modules, variables et état distant Terraform · Revue du plan, dérive, suppression et reconstruction sûres

Les composants OpenStack



Projets et quotas

Frontière du tenant. Les quotas limitent vCPU, RAM, IP et volumes par projet.



Images

Modèles du système de base : Ubuntu 22.04 pour nos nœuds.



Gabarits (flavors)

Taille des VM : vCPU, RAM et disque racine, selon le rôle.



Réseaux et routeurs

Sous-réseau privé des nœuds, routeur vers le réseau externe.



Groupes de sécurité

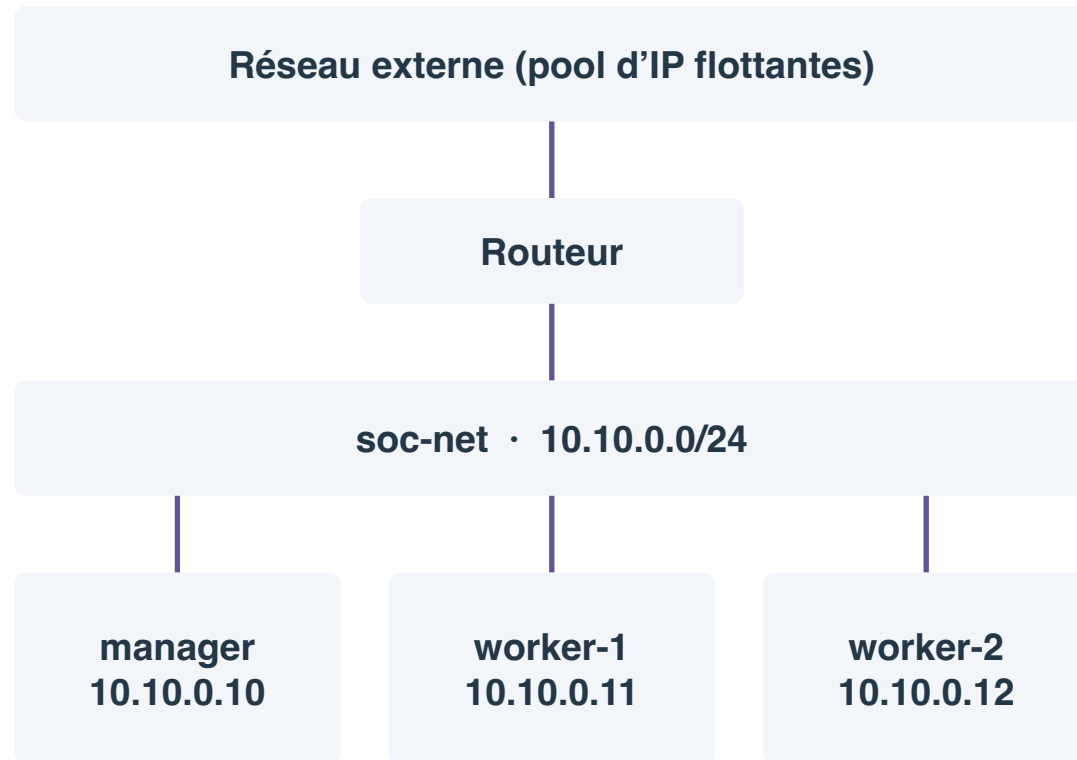
Règles de pare-feu avec suivi d'état sur chaque port de VM.



Paires de clés et IP flottantes

Clé SSH injectée au démarrage. IP publique associée à un port privé.

Réseau et groupes de sécurité du SOC



sg-ssh

22/tcp depuis le CIDR d'administration / formation uniquement.



sg-swarm

2377/tcp, 7946/tcp+udp, 4789/udp depuis 10.10.0.0/24 uniquement.



sg-wazuh

1514, 1515 : réseaux d'agents · 443 : analystes · 55000 : administrateurs.

Créer une VM manuellement dans Horizon



La même opération avec la CLI OpenStack

```
openstack server create --image ubuntu-22.04 --flavor m1.small \
  --network soc-net --security-group sg-ssh --key-name trainee soc-vm-01
openstack floating ip create public
openstack server add floating ip soc-vm-01 <floating-ip>
```

Les fondamentaux de Terraform



Provider et authentication

providers.tf

```
terraform {
  required_version = ">= 1.5"
  required_providers {
    openstack = {
      source  = "terraform-provider-openstack/openstack"
      version = "~> 3.0"
    }
  }
}

provider "openstack" {
  cloud = "soc-lab" # entrée dans clouds.yaml
}
```

~/.config/openstack/clouds.yaml

```
clouds:
  soc-lab:
    auth:
      auth_url: https://keystone.example:5000/v3
      username: trainee01
      project_name: soc-trainee01
      user_domain_name: Default
      project_domain_name: Default
      region_name: RegionOne
```



Identifiants : canal de secrets approuvé ;
jamais dans Git, l'historique ou les logs CI.

Décrire les machines

main.tf

```
resource "openstack_networking_port_v2" "node" {
  for_each      = var.nodes
  name          = "${each.key}-port"
  network_id    = data.openstack_networking_network_v2.soc.id
  security_group_ids = [for sg in openstack_networking_secgroup_v2.soc : sg.id]
}

resource "openstack_compute_instance_v2" "node" {
  for_each      = var.nodes
  name          = each.key
  image_name    = var.image
  flavor_name   = each.value.flavor
  key_pair      = var.key_pair
  network { port = openstack_networking_port_v2.node[each.key].id }
}

resource "openstack_networking_floatingip_v2" "node" {
  for_each = var.nodes
  pool     = var.external_network
  port_id  = openstack_networking_port_v2.node[each.key].id
}
```

- **Port:** raccordement réseau fixe et groupes de sécurité.
- **Instance :** image, gabarit et paire de clés ; démarrage sur le port.
- **IP flottante :** adresse publique associée au même port.
- **for_each:** un bloc pour tous les nœuds de la map.

Variables, modules et sorties

variables.tf · outputs.tf

```
variable "nodes" {
  type = map(object({ flavor = string, role = string }))
  default = {
    "swarm-manager" = { flavor = "m1.large", role = "manager" }
    "swarm-worker-1" = { flavor = "m1.medium", role = "worker" }
    "swarm-worker-2" = { flavor = "m1.medium", role = "worker" }
  }
}

output "node_ips" {
  value = { for k, fip in openstack_networking_floatingip_v2.node :
    k => fip.address }
}
```



Modules

modules/swarm-node regroupe port + VM + IP flottante.



tfvars par environnement

Sélection explicite par -var-file ; état et identifiants isolés.



cloud-init

user_data installe les paquets de base au premier démarrage.

Revue du plan, dérive et reconstruction sûre



Revue du plan

`terraform plan -out=tfplan`

Lire + ~ - et -/+ (remplacement = risque de perte).

Appliquer uniquement le plan sauvegardé et validé.



Détection de dérive

`terraform plan -refresh-only`

-detailed-exitcode : 0 sans dérive, 1 erreur, 2 changements.

Planifier son exécution en CI.



Suppression et reconstruction

`terraform plan -replace=<address>`
`-out=tfplan`

Valider puis appliquer le plan sauvegardé ; protéger les données.

Plan de destruction : état de l'atelier uniquement ; sauvegarder d'abord.

D'Horizon à Terraform

Objectif

Créer une VM manuellement, la reproduire en code et passer aux trois nœuds requis en session 3.

1. Horizon : paire de clés, groupe de sécurité, petite VM, IP flottante.
2. Connectez-vous en SSH et vérifiez son fonctionnement.
3. Supprimez la VM et libérez l'IP flottante.
4. Examinez le Terraform fourni : provider, port, VM, IP.
5. terraform init, plan, apply. Nouvelle connexion SSH.
6. Complétez la map nodes : manager + 2 workers.

Commandes clés

```
terraform init
terraform plan -out=tfplan
terraform apply tfplan
terraform output node_ips
ssh ubuntu@<floating-ip>
```



Critères de réussite

Le plan validé crée trois nœuds d'atelier joignables. Gardez-les pour la session 3 ; toute suppression exige une autorisation ciblée.

03

Docker Swarm

Module source · Création du cluster, rôles des nœuds, réseaux overlay et contraintes de placement · Stack Wazuh, secrets et configurations · Persistance, replanification et comportement en panne

Architecture d'un cluster Swarm



Managers

Stockent l'état du cluster dans Raft, planifient les tâches et exposent l'API. L'un est leader.



Workers

Exécutent les tâches attribuées par les managers. Aucun état du cluster.



Jetons de jonction

Jetons distincts pour managers et workers. Les renouveler en cas de fuite.

Quorum Raft

Managers	Quorum	Pertes tolérées
1	1	0
3	2	1
5	3	2
7	4	3



Nombre impair recommandé. Atelier : 1 (sans HA) ; conception résiliente : 3 ou 5.

Stacks, services et tâches



Le réseau dans Swarm



Réseaux overlay

L2 virtuel entre nœuds via VXLAN (4789/udp). Chiffrement facultatif : `--opt encrypted`.



Maillage de routage ingress

Les ports publiés en mode ingress routent via chaque nœud joignable vers les tâches ; vérifier leur disponibilité.



Publication en mode host

mode: host publie uniquement sur les nœuds des tâches ; vérifier l'IP source de bout en bout.



Découverte des services

DNS intégré : `wazuh.indexer` se résout vers l'IP virtuelle du service.

Contraintes de placement et labels

Attribuer un label au nœud

```
docker node update --label-add wazuh.indexer=true swarm-manager
docker node inspect swarm-manager --format '{{ .Spec.Labels }}'
```

Contraindre le service

```
wazuh.indexer:
  image: wazuh/wazuh-indexer:${WAZUH_VERSION}
  deploy:
    replicas: 1
  placement:
    constraints:
      - node.labels.wazuh.indexer == true
```

- **node.role == manager** restreint aux managers.
- **node.hostname == x** restreint à un hôte (fragile).
- **node.labels.*** décrit une capacité : à privilégier.
- **Aucun nœud éligible ?** La tâche reste Pending.

Wazuh : stack Swarm du formateur

Réseau overlay : wazuh-net

wazuh.manager

Ports 1514, 1515, 55000
Filebeat intégré
Volumes : /var/ossec/*



wazuh.indexer

Port 9200 (interne)
Placement imposé par label
Volume : données de l'indexer



wazuh.dashboard

Publication 443 → 5601
Dialogue avec indexer + API
Volume : configuration

```
docker stack deploy -c wazuh-stack.yml wazuh
docker stack services wazuh
```

Secrets, configurations et certificats



Secrets

Secrets Swarm chiffrés dans Raft ; les images doivent lire explicitement les fichiers secrets montés.



Configurations

ossec.conf, opensearch.yml, wazuh.yml. Montés au chemin cible.



Certificats

CA et certificats aux SAN corrects ; protéger les clés privées, vérifier confiance et expiration.

```
docker secret create root-ca.pem ./certs/root-ca.pem
docker config create ossec_conf_v1 ./config/ossec.conf
```

```
secrets:
- source: root-ca.pem
  target: /usr/share/wazuh-indexer/certs/root-ca.pem
```



Immuables : renouveler sous un nouveau nom (_v2), puis mettre à jour le service.

Où réside l'état ?

Composant	Contenu	Stockage	Si perte
Indexer	Alertes indexées, historique	Volume local du nœud imposé	Historique des alertes perdu
Manager	client.keys, groupes, règles, files	Volumes sous /var/ossec	Réenrôlement, règles personnalisées perdues
Dashboard	Paramètres, objets sauvegardés	Volume de configuration + indexer	Paramètres d'interface réinitialisés
Certificats	Identité TLS des composants	Secrets Swarm	Connexions impossibles



Prérequis indexer : `sysctl -w vm.max_map_count=262144` (à rendre persistant dans /etc/sysctl.d/)

Que se passe-t-il en cas de panne ?



Un worker tombe en panne

Les tâches répliquées sont replanifiées sur les nœuds sains. Les tâches contraintes restent Pending.



Un montage ou volume devient indisponible

Le conteneur échoue ou redémarre. Les données locales ne suivent pas une tâche déplacée.



Perte du quorum des managers

Les tâches actives peuvent continuer ; planification et mises à jour attendent le quorum. Pas de force-new-cluster courant.



Indexer indisponible

L'analyse peut continuer tant que files et disque le permettent. Recherche indisponible ou périmée : réconcilier les lacunes.

Cluster Swarm et stack Wazuh

Objectif

Utiliser trois VM approuvées pour un atelier Wazuh à instance unique par composant, sans promesse de HA.

1. Sur le manager : docker swarm init.
2. Joignez les deux workers avec le jeton worker.
3. Vérifiez avec docker node ls.
4. Labellisez le nœud indexer, réglez vm.max_map_count.
5. Générez les certificats Wazuh.
6. Déployez la stack validée ; vérifiez réplicas ET disponibilité.
7. Ouvrez l'URL du dashboard approuvée avec TLS vérifié.

Commandes clés

```
docker swarm init \  
  --advertise-addr 10.10.0.10  
docker swarm join-token worker  
docker node ls  
docker stack deploy \  
  -c wazuh-stack.yml wazuh  
docker service ls
```



Critères de réussite

Trois nœuds Ready, réplicas attendus, interface/API fiables ; prouver ensuite la collecte récente de bout en bout dans l'atelier 5.

04

Automatisation avec Ansible

Module source · Inventaire, rôles, group_vars et Vault · Installation et configuration automatisées de la stack Wazuh · Déploiement, enrôlement et groupes d'agents à grande échelle · Idempotence et cohérence

Inventaire et group_vars

inventories/lab/hosts.yml

```
all:
  vars:
    ansible_user: ubuntu
  children:
    managers:
      hosts:
        swarm-manager: { ansible_host: 203.0.113.10 }
    workers:
      hosts:
        swarm-worker-1: { ansible_host: 203.0.113.11 }
        swarm-worker-2: { ansible_host: 203.0.113.12 }
```

group_vars/all/vars.yml

```
wazuh_version: "4.x.y" # fixer une version
wazuh_indexer_node: swarm-manager
wazuh_manager_address:
"<WAZUH_MANAGER_ENDPOINT>"
wazuh_agent_group: swarm-nodes
```



Utilisez l'inventaire YAML validé des ressources du formateur.

Organisation du projet en rôles

Arborescence

```
ansible/
├── inventories/lab/
│   ├── hosts.yml
│   └── group_vars/all/
├── roles/
│   ├── docker/           # moteur + SDK
│   ├── swarm_init/       # premier manager
│   ├── swarm_join/       # workers
│   └── wazuh_prereqs/     # sysctl, label,
├── certificats
│   ├── wazuh_stack/      # secrets, déploiement
│   └── wazuh_agent/      # installation, enrôlement
└── site.yml
```

site.yml

```
- hosts: all
  become: true
  roles: [docker]

- hosts: managers[0]
  become: true
  roles: [swarm_init]

- hosts: workers
  become: true
  roles: [swarm_join]

- hosts: managers[0]
  become: true
  roles: [wazuh_prereqs, wazuh_stack]

- hosts: all
  become: true
  roles: [wazuh_agent]
```

Construire le Swarm avec community.docker

roles/swarm_init · roles/swarm_join

```
- name: Initialiser le swarm
  community.docker.docker_swarm:
    state: present
    advertise_addr: "{{ ansible_default_ipv4.address }}"
    register: swarm

- name: Joindre les workers
  community.docker.docker_swarm:
    state: join
    join_token: "{{ hostvars[groups.managers[0]].swarm.swarm_facts.JoinTokens.Worker }}"
    remote_addrs: ["{{ hostvars[groups.managers[0]].ansible_default_ipv4.address }}:2377"]
```



Idempotence

Convergence attendue ; vérifier l'appartenance au cluster.



Sans copier-coller

Jeton lu sur le manager.



Prérequis

SDK Docker pour Python sur les nœuds.

Déployer la stack Wazuh

roles/wazuh_prereqs

```
- name: Paramètre noyau de l'indexer
  ansible.posix.sysctl:
    name: vm.max_map_count
    value: "262144"
    sysctl_set: true

- name: Labelliser le nœud indexer
  community.docker.docker_node:
    hostname: "{{ wazuh_indexer_node }}"
    labels: { wazuh.indexer: "true" }
    labels_state: merge
```

roles/wazuh_stack

```
- name: Secret du mot de passe indexer
  community.docker.docker_secret:
    name: indexer_password
    data: "{{ vault_indexer_password }}"

- name: Déployer la stack
  community.docker.docker_stack:
    name: wazuh
    compose:
      - /opt/wazuh/wazuh-stack.yml
```

Protéger les secrets avec Ansible Vault



Chiffrement au repos

vault.yml chiffré uniquement ; clé protégée séparément.



Préfixe vault_

vars.yml référence les noms vault_*.



Adapté à la CI

Secret protégé et limité ; masquage ≠ isolation.

Commandes

```
ansible-vault create inventories/lab/group_vars/all/vault.yml
```

```
# contenu (chiffré sur disque)
vault_indexer_password: "...
vault_api_password: "...
```

```
# exécution locale
ansible-playbook site.yml --ask-vault-pass
```

```
# exécution CI
ansible-playbook site.yml \
  --vault-password-file "$VAULT_PASS_FILE"
```

Déployer les agents à grande échelle

roles/wazuh_agent/tasks/main.yml

```
- name: Installer l'agent Wazuh
  ansible.builtin.apt:
    name: "wazuh-agent={{ wazuh_version }}-1"
    state: present
  environment:
    WAZUH_MANAGER: "{{ wazuh_manager_address }}"
    WAZUH_AGENT_GROUP: "{{ wazuh_agent_group }}"

- name: Démarrer et activer l'agent
  ansible.builtin.systemd:
    name: wazuh-agent
    state: started
    enabled: true
```

- **Avant** : ajouter le dépôt apt Wazuh et sa clé GPG.
- **Enrôlement** : automatique au premier démarrage, 1515/tcp.
- **Groupes** : définir par groupe d'inventaire dans group_vars.
- **Version** : agent jamais plus récent que le manager.

Idempotence et cohérence



État souhaité

Converger vers l'état validé
; vérifier le comportement.



Check et diff

Simulation partielle ; diff
peut exposer des secrets.



Deuxième exécution

Enquêter sur les
changements répétés
inexpliqués.



Éviter shell

Si nécessaire : creates /
changed_when.

Deuxième exécution : résultat attendu

```
$ ansible-playbook site.yml
```

```
PLAY RECAP *****
swarm-manager   : ok=31  changed=0  failed=0
swarm-worker-1  : ok=14  changed=0  failed=0
swarm-worker-2  : ok=14  changed=0  failed=0
```

Tout reconstruire en une commande

Objectif

Reconstruire l'environnement de la session 3 depuis zéro avec Terraform et une exécution Ansible.

1. Validez les plans ciblés ; conservez les données de reprise.
2. Générez hosts.yml depuis terraform output.
3. Lisez le playbook et les rôles fournis.
4. Placez les mots de passe dans vault.yml chiffré.
5. Exécutez ansible-playbook site.yml.
6. Vérifiez nœuds, services et dashboard.
7. Relancez : aucun changement inexpliqué ni échec.

Commandes clés

```
ansible-galaxy collection install \
  community.docker ansible.posix
ansible-vault create ../vault.yml
ansible-playbook -i inventories/lab \
  site.yml --ask-vault-pass
```



Critères de réussite

Convergence, contrôles fiables et télémétrie récente ; aucun changement inexpliqué au second passage. Ne prouve pas la reprise.

05

Exploitation des services

Module source · Santé de chaque composant · Décodeurs, règles et configuration centralisée des agents · Mises à niveau progressives, snapshots et reprise · Déploiement canari, retour arrière et preuve de reprise

Visite du dashboard



Agents

État, OS, version, groupes et dernier signal de vie de chaque endpoint.



Événements de sécurité

Alertes par niveau, règle, agent et heure. Vue principale de l'analyste.



Surveillance de l'intégrité

Fichiers ajoutés, modifiés ou supprimés, avec hash et attributs.



Détection des vulnérabilités

Paquets installés rapprochés des flux CVE, par gravité.



MITRE ATT&CK

Alertes associées aux tactiques et techniques.



Discover / threat hunting

Recherche dans wazuh-alerts-* avec filtres et requêtes enregistrées.

Sysmon et osquery : enrichir sans tout collecter

01

Sysmon décrit des activités

Sysmon enrichit les événements Windows, notamment sur les processus et certaines connexions selon sa configuration. Wazuh doit collecter le canal prévu ; installer l'outil ne prouve pas l'ingestion.

02

osquery décrit un état

Des requêtes planifiées peuvent produire des résultats ou différences de résultats. Une ligne added ou removed s'interprète par rapport à la requête, à son état antérieur et à sa périodicité.

03

Limiter coût et exposition

Choisir les données répondant à une question SOC, revoir les configurations et mesurer la charge. Ne pas récupérer et exécuter aveuglément des règles ou paquets externes.

RBAC : utilisateurs, rôles et associations



Profil	Accès dashboard / indexer	Rôle API Wazuh
SOC Analyst (L1)	Lecture des index autorisés + tenant en lecture seule	readonly
Ingénieur SOC	Lecture, écriture et gestion des dashboards	Politique d'ingénierie limitée
Opérateur d'agents	Lecture des alertes	Politique limitée aux agents

Lecture seule : contrôler indexer et API

01

Sécurité des données indexées

Limiter permissions d'index et de tenant aux données d'atelier nécessaires. Éviter les motifs globaux dans un environnement partagé et vérifier les index requis par la version.

02

Sécurité de l'API Wazuh

Associer aussi l'utilisateur à une politique API de lecture appropriée. Le contexte d'autorisation transmis par le dashboard, notamment `run_as`, doit être vérifié par le formateur.

03

Prouver les deux frontières

Avec une nouvelle session lecteur, vérifier lecture autorisée et refus ou omission des données hors périmètre dans les deux couches. Ne pas tester la restriction par une suppression réelle.

Comment un agent rejoint le SOC



Commandes

```
WAZUH_MANAGER="<WAZUH_MANAGER_ENDPOINT>" WAZUH_AGENT_GROUP="swarm-nodes" apt-get install -y wazuh-agent  
systemctl enable --now wazuh-agent
```

```
# sur le nœud du manager Wazuh  
docker exec $(docker ps -q -f name=wazuh_wazuh.manager) /var/ossec/bin/agent_control -l
```

Enrôlement : identité unique et bon point d'accès

01

Inspecter avant d'enrôler

Vérifier si l'agent existe déjà, son identifiant, son hôte, son groupe et sa version. Ne pas réinstaller ou réenrôler automatiquement un agent déjà conforme.

02

Séparer les flux

Confirmer les points d'accès d'enrôlement et d'événements du manifeste. Les ports usuels sont TCP 1515 et TCP 1514 ; l'IP du manager Swarm n'est pas automatiquement celle du service Wazuh.

03

Vérifier après inscription

Confronter journal de l'agent, état de connexion et inventaire du manager. Une clé reçue prouve une étape d'inscription, pas encore la couverture des journaux ou du FIM.

Groupes : prouver la configuration effective

01

Centraliser sans écraser au hasard

Le manager distribue agent.conf selon les groupes. Le fichier local ossec.conf et les configurations partagées participent au résultat ; modifier la copie distribuée sur l'agent n'est pas une gestion durable.

02

Valider puis synchroniser

Sauvegarder la configuration et les appartenances, valider avec verify-agent-conf selon la version, puis déployer sur un groupe canari. Contrôler réception et application, pas seulement syntaxe.

03

Vérifier les conflits

Un agent peut appartenir à plusieurs groupes. Examiner l'ordre et les règles de fusion de la version, puis lire la configuration effective et observer le comportement attendu.

Contrôler la santé des composants

Composant	Contrôle	État sain si...
Swarm	<code>docker service ls</code>	Réplicas attendus + disponibilité + sonde récente
Manager	<code>wazuh-control status</code>	Démons activés attendus + analyse récente
Agents	<code>agent_control -l</code>	État Active
Filebeat	<code>filebeat test output</code>	Connexion à l'indexer opérationnelle
Indexer	<code>GET _cluster/health</code>	Primaires alloués ; écarts de réplicas expliqués
API Wazuh	<code>GET :55000/ avec jeton</code>	HTTP 200 avec version
Dashboard	<code>https://<ip>/</code>	TLS vérifié, lectures limitées, alerte récente retrouvée

Distinguer disponibilité et couverture réelle

01

Les états sont partiels

Un service démarré, un réplica 1/1 ou un agent Active renseigne une partie du système. Aucun de ces états ne démontre seul que les événements attendus deviennent consultables.

02

Suivre une sonde récente

Utiliser le canari inoffensif autorisé et rapprocher agent, chemin, heure et changement attendu. Vérifier la source, l'alerte du manager puis le résultat indexé sous le compte lecteur.

03

Mesurer la fraîcheur

Consigner heure de production, heure d'observation et latence par rapport à l'échéance définie. Une ancienne alerte visible prouve un historique, pas le fonctionnement actuel.

Indexation : diagnostiquer une alerte invisible

01

Partir de l'alerte exacte

Si l'alerte est présente sur le manager, vérifier ensuite transmission, erreurs d'ingestion et index destination. Ne pas recommencer l'événement source avant d'avoir localisé la rupture.

02

Vérifier la recherche

Contrôler index ou vue de données, champ temporel, intervalle, fuseau et permissions. Un filtre trop étroit ou un rôle limité peut rendre invisible un document pourtant indexé.

03

Lire la santé avec précision

Tous les primaires alloués avec un réplica manquant peuvent donner yellow. Un indexer unique sans réplica peut être green sans redondance ; la couleur ne prouve pas la reprise ni la fraîcheur.

Décodeurs et règles personnalisés

etc/decoders/local_decoder.xml

```
<decoder name="socapp">
  <prematch>^socapp: </prematch>
</decoder>

<decoder name="socapp-login">
  <parent>socapp</parent>
  <regex type="pcre2">login failed for user (\S+) from
(\S+)</regex>
  <order>user, srcip</order>
</decoder>
```

etc/rules/local_rules.xml

```
<group name="socapp,">
  <rule id="100100" level="7">
    <decoded_as>socapp</decoded_as>
    <match>login failed</match>
    <description>Échec de connexion : $(user)</
description>
    <!-- Associer MITRE uniquement si justifié. -->
  </rule>
</group>
```



Avant redémarrage : wazuh-logtest, puis wazuh-analysisd -t pour valider toutes les règles.

Décodage : extraire avant de décider

01

Pré-décoder le contexte

Le pré-décodage reconnaît notamment certains en-têtes : heure, hôte ou programme. Leur disponibilité dépend du format réel ; tous les journaux n'ont pas la même structure.

02

Extraire des champs utiles

Le décodeur transforme les données en champs comme adresse source, utilisateur ou action. Une règle précise dépend d'une extraction correcte, pas seulement de mots présents dans le texte.

03

Tester les variantes

Comparer une ligne attendue, une variante légitime et une entrée incomplète. Vérifier les champs extraits ; un décodeur qui accepte une seule ligne de démonstration reste fragile.

Règles : comprendre la logique de déclenchement

01

Lire la règle et ses parents

L'identifiant, les conditions, le niveau et les relations avec d'autres règles expliquent le déclenchement. Distinguer correspondance d'un événement et corrélation de plusieurs événements.

02

Préserver les règles du produit

Les personnalisations vont dans les emplacements locaux prévus, pas dans les fichiers du jeu livré. Documenter objectif, exemples, périmètre, propriétaire et procédure de retour arrière.

03

Interpréter sans surconclure

Un niveau de règle ou une association MITRE aide au triage. Il ne prouve ni compromission, ni attribution, ni gravité métier ; examiner les champs et le contexte.

wazuh-logtest : tester positifs et négatifs

01

Tester hors trafic réel

Soumettre des journaux synthétiques ou expurgés à wazuh-logtest permet d'observer pré-décodage, décodage et règle résultante. Aucun essai de mots de passe sur un service n'est nécessaire.

02

Énoncer les résultats attendus

Pour chaque cas, préciser champs, règle et niveau attendus, ou absence de la règle ciblée. Inclure variante bénigne, champ absent et limites temporelles pour les corrélations.

03

Compléter par un canari

Un test de règles réussi ne prouve pas collecte, distribution, chargement effectif ou indexation. Après validation, vérifier un événement récent dans la chaîne réelle autorisée.

Active Response : décider avant d'automatiser

01

Une action change le système

Une réponse active peut bloquer un accès ou modifier un hôte. Un faux positif peut interrompre une activité légitime ; le niveau d'alerte seul n'autorise pas une action automatique.

02

Définir les garde-fous

Préciser déclencheur, périmètre, approbateur, exclusions, durée, journal d'action, accès de secours et méthode d'annulation. Vérifier si la réponse est réellement réversible.

03

Rester sur table dans ce parcours

Analyser une proposition et ses risques sans activer de blocage. Le guide n'autorise ni Active Response ni confinement en production ; une expérimentation exige un mandat séparé et explicite.

Configuration centralisée des agents

agent.conf du groupe swarm-nodes

```
<!-- /var/ossec/etc/shared/swarm-nodes/agent.conf -->
<agent_config>
  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/socapp.log</location>
  </localfile>
  <syscheck>
    <directories realtime="yes">/var/tmp/soc-lab-fim</directories>
  </syscheck>
</agent_config>
```



Par groupe

Un agent.conf par groupe.



Diffusion

Les agents récupèrent eux-mêmes les changements.



Vérification

verify-agent-conf avant enregistrement.

FIM : référence, modes et données sensibles

01

Comparer à une référence

FIM suit des propriétés de fichiers : contenu, empreintes, droits ou propriétaire selon la configuration. Une modification signale une différence à expliquer, pas nécessairement une attaque.

02

Choisir le mode adapté

Analyse planifiée, surveillance en temps réel et who-data apportent des informations différentes. Les possibilités et dépendances d'audit varient entre Linux, Windows et systèmes de fichiers.

03

Éviter la collecte excessive

La remontée des différences de contenu peut exposer des secrets. Surveiller un répertoire d'atelier dédié ; ne pas activer une collecte large de contenus sensibles pour la démonstration.

Canari FIM : protocole de recette bout en bout

01

Préparer le périmètre

Créer un groupe canari approuvé avec un seul agent jetable. Conserver appartenance et politique initiales ; valider la surveillance de /var/tmp/soc-lab-fim fourni pour l'exercice.

02

Observer une modification

Attendre la référence initiale de marker.txt, puis ajouter un marqueur unique autorisé. Suivre identifiant d'agent, chemin, heure et empreintes ; le texte du marqueur n'est pas forcément remonté.

03

Accepter ou arrêter

Exiger alerte manager puis vue indexée sous le rôle lecteur, dans l'échéance du formateur. En cas d'échec, diagnostiquer ; après preuve, restaurer la politique et retirer seulement l'artefact d'atelier.

Mises à niveau, snapshots et reprise



Mises à niveau progressives

Plan adapté aux versions, canari et sauvegarde exigés.

Ordre : indexer → manager → dashboard → agents.



Snapshots

Enregistrer un dépôt fs (path.repo).

PUT _snapshot/soc-backup/<date>

Plus les sauvegardes des volumes / var/ossec.



Procédures de reprise

Procédure du formateur : état compatible, identités, TLS, données historiques ET événement récent prouvé.

Mises à niveau : vérifier le comportement après

01

Préparer la compatibilité

Fixer les versions et vérifier leur matrice de compatibilité.
Conserver configuration, preuves et sauvegardes nécessaires ; choisir un agent canari plutôt qu'une mise à niveau globale non revue.

02

Lire le résultat réel

Une tâche acceptée ou en cours n'est pas une mise à niveau terminée. Vérifier résultat final, version rapportée, connexion et configuration effective de l'agent ciblé.

03

Rejouer la recette

Après changement, suivre un événement récent jusqu'à la recherche et comparer les comportements attendus. Le retour arrière dépend de la compatibilité des données, pas seulement d'un ancien paquet disponible.

Utilisateurs, agents et alertes réelles

Objectif

Créer un utilisateur limité, enrôler les VM OpenStack et générer des alertes retrouvables.

1. Parcourez les modules du dashboard.
2. Associez les rôles tenant/index ET API en lecture seule.
3. Connectez-vous avec ce compte et vérifiez ses limites.
4. Installez et enrôlez l'agent sur chaque VM.
5. Vérifiez l'état Active avec `agent_control -l`.
6. Utilisez des sondes bornées autorisées et un fichier FIM dédié.
7. Bonus : diffusez un `agent.conf` à `swarm-nodes`.

Commandes clés

```
# Un seul canari approuvé ; aucune boucle  
d'essais  
sudo -l  
# Modifier uniquement /var/tmp/soc-lab-fim/  
marker.txt  
/var/ossec/bin/agent_control -l
```



Critères de réussite

Trois agents Active uniques ; lecture seule limitée ; sonde récente attendue suivie de la source au manager puis à la recherche.

06

GitLab CI

Module source · Dépôt detection-as-code et branches · Étapes : lint, validation XML, wazuh-logtest · Canari puis production · Approbations, tests bloquants, retour arrière et traçabilité

Extrait conceptuel CI — non exécutable en l'état

```
stages: [lint, validate, test, deploy-canary, deploy-lab]

lint:
  stage: lint
  script: [yamllint ., ansible-lint ansible/, terraform -chdir=terraform fmt -check]

logtest:
  stage: test
  image: wazuh/wazuh-manager:${WAZUH_VERSION}
  script: [./scripts/run-logtests.sh detection/tests]

deploy-canary:
  stage: deploy-canary
  script: [ansible-playbook -i inventories/canary site.yml --tags detection]
  environment: { name: canary }
  rules: [{ if: '$CI_COMMIT_BRANCH == "main"' }]

deploy-lab:
  stage: deploy-lab
  script: [ansible-playbook -i inventories/lab site.yml --tags detection]
  environment: { name: lab-promotion }
  rules: [{ if: '$CI_COMMIT_BRANCH == "main"', when: manual }]
```

Contrôles, retour arrière et traçabilité



Approbations obligatoires

Branche main protégée, approbations MR requises, environnement de production protégé et approbateurs nommés.



Tests en échec = blocage

Pipeline réussi exigé pour fusionner. Un logtest en échec bloque le déploiement.



Retour arrière conçu

Exiger des contrôles de santé et une reprise testée ; une ancienne image/tag n'inverse pas les migrations d'état.



Piste d'audit

Commit, MR, pipeline et déploiement : qui, quoi, quand et approbateur.

Évaluation finale

Objectif

Mesurer les acquis et combler ensemble les lacunes restantes.

1. Ouvrez le formulaire final.
2. Répondez à 10–15 questions, dont certaines de la session 1.
3. Envoyez et comparez avec votre score de session 1.
4. Échangez sur les sujets les moins maîtrisés.

Exemples de scénarios

- Ajouter un 4e worker : quels fichiers changer, quels jobs lancer ?
- Une règle alerte sur des logs bénins : où devrait-on détecter le problème ?
- Le nœud indexer est perdu : que faut-il restaurer ?



Critères de réussite

Comparez les questions répétées, notez et revoyez les lacunes. La progression est un objectif, pas un résultat garanti.

Ce que vous savez désormais faire



Architecture

Expliquer les composants et le parcours d'un événement.



Provisionnement

Créer les VM OpenStack en code, avec état partagé verrouillé.



Orchestration

Expliquer les limites de résilience du Swarm personnalisé.



Automatisation

Vérifier la convergence ; distinguer reconstruction et restauration.



Exploitation

Enrôler, gérer les accès, écrire et tester les règles.



Livraison

Concevoir contrôles et preuves pour une livraison maîtrisée.

M E R C I

Questions ?

Avant de partir : conservez les preuves autorisées, validez avec le formateur un plan de destruction limité à l'atelier, puis réconciliez les ressources enregistrées.

Cyber Academy · CIRE Technologies

Synthèse : du signal à une décision défendable

01

Scénario commun

Le dossier fictif réunit échecs SSH, connexion réussie, modification FIM et alerte absente de la recherche. Une maintenance était prévue, mais son périmètre n'est pas confirmé ; l'agent reste Active.

02

Travail demandé

Construire une chronologie, séparer faits et hypothèses, proposer les vérifications prioritaires et dessiner la chaîne Wazuh. Identifier la première preuve manquante et l'autorité nécessaire avant toute action.

03

Livrable attendu

Remettre une fiche d'incident provisoire, une matrice de preuves et un plan de recette/reprise. Infrastructure fournie : canari autorisé possible ; sinon, dossier uniquement, sans prétention de déploiement.

Corrigé : distinguer incident et défaut de visibilité

01

Ce qui est établi

Les pièces prouvent les événements rapportés par leurs sources et une visibilité incomplète. Échecs puis succès ne prouvent pas, seuls, une usurpation ; un changement FIM ne prouve pas une persistance malveillante.

02

Ce qui départage les hypothèses

Vérifier identité, heure, hôte, périmètre de maintenance et contenu autorisé. Chercher l'alerte exacte au manager, puis contrôler transmission, index, plage temporelle et droits du lecteur.

03

Décision argumentée

Ouvrir ou maintenir l'investigation selon le risque et les preuves ; escalader les inconnues critiques. La recette reste non acquise sans événement récent suivi de bout en bout et accès limités vérifiés.

Évaluation : mesurer des compétences observables

01

Barème sur 100

Bases J1 : 25 ; investigation J2 : 35 ; architecture et recette J3 : 30 ; restitution individuelle : 10.
Total : 100. Chaque note repose sur une explication ou une preuve, pas sur un badge.

02

Seuil et règle de sécurité

Validation à partir de 70/100 avec respect des garde-fous. Hors périmètre, secret exposé, confiance TLS contournée ou action destructive non autorisée : arrêt, analyse et remédiation avant validation.

03

Nommer le niveau démontré

Distinguer connaissance, analyse sur dossier et pratique observée. Une réussite sur pièces synthétiques n'atteste pas la capacité à déployer ou exploiter seul une infrastructure de production.

Conclure : passer le relais avec des preuves

01

Un parcours, deux responsabilités

L'analyste transforme les traces en décisions argumentées ; l'architecte rend la collecte, l'analyse, les accès et la reprise vérifiables. Les deux partagent besoin métier, limites et critères de preuve.

02

Une remise structurée

Transmettre périmètre, versions, schéma, sources surveillées, règles revues, droits, résultats du canari et plan de reprise. Identifier les preuves absentes sans les remplacer par une promesse.

03

Fermer et poursuivre proprement

Conserver uniquement les preuves autorisées, retirer les artefacts d'atelier avec accord et révoquer les accès temporaires. Définir ensuite une pratique accompagnée ciblant les compétences non encore démontrées.